VOXIMIUS

Présentation du protocole

Voxaly-Docaposte

12 août 2026





Résumé

Voximius est un protocole de vote par internet que nous, Voxaly-Docaposte, avons développé dans le cadre d'un contrat avec le ministère de l'Europe et des Affaires étrangères (MEAE). Son but est de permettre aux français établis hors de France de voter par internet lors de différentes élections, notamment les élections consulaires et législatives. Le ministère a fait part de ses exigences lors d'un appel d'offre public que nous avons remporté, et ce document s'efforce de décrire notre protocole ainsi que la manière dont il répond à ces demandes. Le code source du client de vote est consultable [Vox26]. Pour toute demande concernant le protocole de vote, veuillez utiliser l'adresse de contact contact-vpi.fae-sfe-adf@diplomatie.gouv.fr.

Notice de propriété intellectuelle. Ce document, ainsi que l'ensemble des informations qu'il contient, sont la propriété exclusive de Voxaly-Docaposte. Le présent document n'a pas vocation à opérer le moindre transfert de propriété. Par cette notice, la permission est accordée à toute personne obtenant une copie de cette documentation de l'utiliser gratuitement afin d'effectuer des opérations de vérifiabilité individuelle ou universelle, ce dans le cadre d'un contrat avec le ministère de l'Europe et des Affaires étrangères. Ce droit d'utilisation implique des droits de copie, de modification, de fusion et de publication, sous réserve du respect de la condition suivante :

- La présente notice de propriété intellectuelle doit être incluse dans toute documentation reprenant une partie substantielle de ce document ou ayant été établie à partir d'informations présentes dans ce document, ce qui inclut les republications.

En tout état de cause, toute personne ayant accès à ce document ou à toute documentation dérivée s'interdit d'en faire une exploitation commerciale, à moins d'avoir préalablement obtenu l'accord écrit et explicite de Voxaly-Docaposte.

Variantes. Il existe trois variantes de ce document :

- La première variante présente Voximius en tant que protocole de vote. Elle ne contient aucun détail d'implémentation ou pseudo-code. Elle est à destination du public et est diffusée sans restriction. Son niveau de confidentialité est C0.
- La deuxième variante contient uniquement les spécifications nécessaires à la bonne réalisation des processus de vérifiabilité individuelle et universelle. Elle est destinée au tiers en charge de ces processus (le tiers VIVU) ; son niveau de confidentialité est C1.
- Enfin, la troisième variante est exhaustive. Elle est réservée au MEAE, aux experts indépendants faisant l'audit de notre solution, à l'agence nationale de la sécurité des systèmes informatiques (l'ANSSI) ainsi qu'à des usages internes par Voxaly. Le niveau de confidentialité de cette version est C3.

Le présent document correspond à la première variante.

Table des matières

Introduction **4**

I Présentation générale **6**
I.1 Les élections pour les Français de l'étranger 7
I.2 Les acteurs et leurs responsabilités 7
I.2.1 Désignation des acteurs 8
I.2.2 Nos hypothèses de confiance 9
I.2.2.a Les points de défaillance uniques 9
I.2.2.b Les hypothèses de non collusion 10
I.2.2.c Quelques scénarios d'attaque 11
I.2.3 Sur la sécurité de l'hébergement 12
I.3 Présentation des différentes phases 13
I.3.1 La mise en place 13
I.3.2 La phase de vote 14
I.3.3 La phase après clôture 15
I.4 Scellements et contrôles d'intégrité 15
I.5 Les propriétés de sécurité de notre protocole 16
I.6 Les primitives cryptographiques 17
I.6.1 Le hachage cryptographique 17
I.6.2 La cryptographie sur courbe elliptique 18
I.6.3 Le chiffrement ElGamal exponentiel 19
I.6.4 La signature électronique 19
I.6.5 Les preuves à divulgation nulle de connaissance 20
I.6.5.a La preuve de bon mélange 20
I.6.5.b La preuve d'exponentiation commune 20

II La phase de mise en place **21**
II.1 Les référentiels électoraux 21
II.1.1 Les fichiers principaux 21
II.1.2 Autres fichiers techniques 23
II.2 La génération des secrets d'authentification 24
II.2.1 Détails des flux et chronologie 24
II.2.2 Génération de EL_CODE_CC_LOGIN par le SI CODE 25
II.2.3 Génération des identifiants et des mots de passe 26
II.2.3.a Inventaire et contenu des fichiers générés par le SI CODE_{B} . 26

II.2.3.b Inventaire et contenu des fichiers générés par SI CODE . . . 27
II.2.3.c Algorithmes de génération des fichiers . . . 28
II.2.3.d Chiffrement des identifiants et mots de passe pour publipostage 28
II.2.4 Fusion et import des authentifications . . . 28
II.3 La génération de la clef de chiffrement des suffrages . . . 29
II.3.1 Les principes . . . 29
II.3.2 La mise en oeuvre . . . 29

III La phase de vote **31**
III.1 Les demandes de renouvellement . . . 31
III.1.1 Authentification d'une demande de renouvellement . . . 32
III.1.1.a Demande de renouvellement de l'identifiant . . . 32
III.1.1.b Demande de renouvellement du mot de passe . . . 33
III.1.2 Résolution d'une demande de renouvellement . . . 33
III.1.2.a En cas de renouvellement de l'identifiant . . . 33
III.1.2.b En cas de renouvellement du mot de passe . . . 34
III.2 L'authentification des électeurs . . . 34
III.2.1 Authentification par identifiant et mot de passe . . . 34
III.2.2 Authentification par France Identité Numérique . . . 35
III.2.2.a Principe . . . 35
III.2.2.b Réconciliation . . . 36
III.2.3 Partage d'une clef publique anonymisée . . . 37
III.3 Création d'un bulletin chiffré, valide et légitime . . . 37
III.3.1 Chiffrement du choix de l'électeur et preuves de validité . . . 37
III.3.2 Signature du bulletin par le client de vote . . . 39
III.3.3 Validation du vote . . . 39
III.3.4 Enregistrement de la transaction de vote . . . 39
III.3.5 Émission d'un cachet serveur . . . 40
III.3.6 Confirmation du vote . . . 40
III.4 La vérification individuelle . . . 40
III.4.1 Vérification automatique par le navigateur . . . 40
III.4.2 L'accusé de réception et le cachet serveur . . . 40

IV La phase après clôture **42**
IV.1 Export des bulletins et des émargements . . . 42
IV.2 Publication des preuves de légitimité . . . 44
IV.2.1 Légitimité des clefs de vérification liées aux émargements . . . 44
IV.2.2 Légitimité des clefs de vérification liées aux bulletins . . . 46
IV.3 Dépouillement et preuves de déchiffrement . . . 47
IV.3.1 Format des déchiffrements avec preuve . . . 48
IV.3.2 Vérification des preuves de bon déchiffrement . . . 48
IV.3.3 Vérification du résultat de comptage . . . 49
IV.3.3.a Format des résultats de comptage . . . 49
IV.3.3.b Vérification des résultats de comptage . . . 50

Conclusion **51**

Bibliographie **54**

Introduction

L'utilisation du vote par internet se répand de plus en plus, non seulement pour les élections professionnelles mais également dans le cadre d'élections politiques. Depuis quelques années, la France utilise cette technologie pour faciliter l'accès aux urnes pour les Français établis hors de France. En particulier, le vote par internet a été utilisé à plusieurs reprises pour les élections législatives des français de l'étranger, ce qui représente 11 circonscriptions. Du fait de l'enjeu important de telles élections, le ministère de l'Europe et des affaires étrangères (MEAE) se permet d'énoncer des exigences bien particulières, en accord avec les conseils de l'agence nationale de la sécurité des systèmes d'information (ANSSI) et les objectifs de sécurité définis par la commission nationale de l'informatique et des libertés (CNIL). Ces exigences ont été revues à la hausse lors du dernier appel d'offre publique émis par le MEAE en 2024, qui a notamment vu apparaître une demande concernant la légitimité des bulletins dans l'urne. Pour y répondre, nous avons développé un nouveau protocole que nous présentons dans ce document. Les spécifications de ce protocole ont été étudiées par l'ANSSI et son implémentation sera auditée par des experts indépendants.

Qui sommes-nous ? La société Voxaly-Docaposte est un fournisseur de solution de vote par internet qui possède une grande expertise de par son ancienneté et sa position sur le marché. En particulier, elle a déjà fourni une solution pour le vote par internet des français de l'étranger dans le cadre des élections législatives de 2022 et 2024. Créée en 2006, Voxaly est désormais une marque de Docaposte. À ce titre, elle œuvre pour la souveraineté numérique et son actionnariat est public. En tant que membre de la fédération des tiers de confiance du numérique, Voxaly peut être considérée comme un acteur de confiance ; elle est de fait soumise à une charte d'éthique et refuse toute forme de monétisation des données personnelles. Pour communiquer avec les électeurs, Voxaly fait appel à deux prestataires principaux : Orange pour l'envoi des courriels et MTarget pour l'envoi des SMS et des messages instantanés. Pour effectuer des horodatages certifiés, elle fait appel à Certinomis, un prestataire qualifié.

Voximius. Un point particulier du cahier des charges du MEAE est de décrire un mécanisme permettant de détecter le bourrage d'urne, y compris de la part de la plateforme de vote. Dans notre réponse, nous avons proposé *Voximius*, qui permet de vérifier la légitimité des bulletins dans l'urne.

La première idée de Voximius est de fournir aux électeurs, ou plutôt à leur client de vote, une clef privée leur permettant de signer leur bulletin. Pour être légitime, un bulletin doit donc posséder une signature valide vis-à-vis d'une clef de vérification référencée. Ce genre de stratégies est connu de la littérature académique [CGGI14] et protège contre le bourrage

d'urne tant que l'attaquant n'a pas simultanément accès à l'urne et aux clefs de signature. Dans notre protocole, la connaissance d'une clef de signature nécessite la connaissance simultanée d'un identifiant et d'un mot de passe. Les mots de passe sont générés par le SI CODE (sous la responsabilité par le MEAE) et les identifiants sont générés de manière indépendante par le SI CODE_{B} (sous la responsabilité d'un tiers).

La deuxième idée de Voximius est de coupler la génération des clefs de signature à celle des secrets d'authentification. Il s'agit là d'une innovation par rapport à la littérature académique, le but étant de ne pas impacter l'expérience utilisateur en demandant aux électeurs de recevoir, conserver et saisir un secret supplémentaire. À la place, la clef de signature est reconstituée par le client de vote à partir des secrets d'authentification saisis par l'électeur, ce à l'aide de chaînes de dérivation. Du point de vue de l'électeur, l'intégration de Voximius est donc transparente au sens où il n'a que deux secrets : un identifiant et un mot de passe. Pour chacun de ces secrets, l'électeur peut faire une demande de renouvellement qui est gérée par le serveur de vote. Dans ce cas, ce dernier génère un nouveau secret mais n'apprend pas l'autre, la connaissance des deux secrets étant nécessaire pour reconstituer la clef de signature. (Du fait du risque associé, notre solution n'autorise les électeurs qu'à faire une demande de renouvellement pour l'un des deux secrets, mais pas les deux.) Afin de permettre aux électeurs de s'authentifier via France identité numérique (FIN), nous proposons un parcours alternatif pour les électeurs concernés. Pour cela, nous nous sommes inspirés de [CDGH24] et nous faisons en sorte que la clef de signature soit générée *à la volée* par le client de vote : la clef de vérification correspondante est alors authentifiée via le protocole d'authentification de FIN.

Enfin, la troisième idée de Voximius est d'ajouter une couche d'anonymisation des clefs de vérification, afin de ne pas divulguer de lien entre l'identité des électeurs et leurs bulletins de vote. Cela est rendu possible grâce au lien qui existe entre les paires de clefs utilisées lors de la signature des bulletins et celles qui interviennent lors d'un échange de secret à la Diffie-Hellman. Ainsi, la clef publique anonymisée peut être vue comme le résultat d'un partage de clef entre le client de vote et le serveur de vote ; elle est donc indistinguable d'une clef aléatoire. Malgré les similarités, il ne s'agit pas *réellement* d'un mécanisme d'encapsulation de clef, ces derniers faisant l'objet de recommandations particulières (comme, par exemple, de ne pas divulguer l'information partagée).

Structure du document. Ce document est divisé en quatre parties. La première donne une présentation générale de Voximius. Sans entrer dans les détails, elle permet de comprendre le fonctionnement global du protocole ainsi que les propriétés recherchées. Les trois parties qui suivent détaillent chacune une phase de notre protocole : la phase avant-vote qui se déroule avant l'ouverture du scrutin, la phase de vote pendant laquelle les électeurs peuvent soumettre des bulletins par internet et la phase après clôture qui comprend le dépouillement et la proclamation des résultats.

Chapitre I

Présentation générale

Voximius est un protocole de vote par internet créé sur le modèle de Belenios [CGG19]. Les électeurs s'authentifient à l'aide d'un identifiant et d'un mot de passe ou par une identité numérique de niveau élevé, et leur bulletin est chiffré et signé. La signature permet de vérifier la légitimité du bulletin tandis que le chiffrement protège la confidentialité du choix de l'électeur. Pour chiffrer, on utilise le cryptosystème ElGamal, un chiffrement à clef publique qui possède une propriété d'homomorphisme. Cette propriété permet d'*additionner* les contenus des bulletins entre eux lors d'une phase d'accumulation. De cette manière, on obtient les résultats de comptage sous une forme chiffrée, ce sans effectuer le moindre déchiffrement. On a alors une *accumulation* par résultat de comptage. Ces dernières sont déchiffrées lors du dépouillement, ce qui révèle les résultats de comptage. Ainsi, aucun bulletin n'est déchiffré individuellement et seuls les résultats pour la granularité désirée sont calculés. Pour protéger la sincérité de l'opération électorale, chaque bulletin s'accompagne de preuves qui montrent qu'il contient un choix valide, ce sans révéler le choix. D'autres preuves sont également utilisées pour montrer que les résultats correspondent bien au déchiffrement des accumulations.

Sommaire

I.1 Les élections pour les Français de l'étranger 7
I.2 Les acteurs et leurs responsabilités 7
I.2.1 Désignation des acteurs 8
I.2.2 Nos hypothèses de confiance 9
I.2.3 Sur la sécurité de l'hébergement 12
I.3 Présentation des différentes phases 13
I.3.1 La mise en place 13
I.3.2 La phase de vote 14
I.3.3 La phase après clôture 15
I.4 Scellements et contrôles d'intégrité 15
I.5 Les propriétés de sécurité de notre protocole 16
I.6 Les primitives cryptographiques 17
I.6.1 Le hachage cryptographique 17
I.6.2 La cryptographie sur courbe elliptique 18
I.6.3 Le chiffrement ElGamal exponentiel 19

I.6.4 La signature électronique 19
I.6.5 Les preuves à divulgation nulle de connaissance 20

I.1 Les élections pour les Français de l'étranger

Les élections législatives consistent à élire un député et un remplaçant pour chacune des 11 circonscriptions législatives des Français de l'étranger. Chaque député est élu au scrutin uninominal majoritaire à deux tours, pour un mandat de cinq ans. Les électeurs disposent de quatre modalités de vote, à savoir le vote à l'urne, le vote par procuration, le vote par correspondance sous pli fermé et le vote par internet.

Les élections consulaires consistent à élire des conseillers et des délégués dans chacune des 130 circonscriptions consulaires. Le nombre de sièges de conseillers consulaires par circonscription varie entre un et neuf, en fonction du nombre d'inscrits au registre des Français établis hors de France. Les conseillers et délégués consulaires sont élus, tous les six ans, selon un mode de scrutin mixte. Dans les circonscriptions où un unique siège est à pourvoir, l'élection a lieu au scrutin uninominal majoritaire à un tour. Dans celles où plusieurs sièges sont à pourvoir, l'élection a lieu au scrutin de liste à un tour, à la représentation proportionnelle suivant la règle de la plus forte moyenne, sans adjonction ni suppression de noms et sans modification de l'ordre de présentation. Pour l'élection des conseillers et délégués consulaires, les électeurs disposent de trois modalités de vote, à savoir le vote à l'urne, le vote par procuration et le vote par internet.

Dans les deux cas, les électeurs sont les citoyens inscrits sur la liste électorale consulaire.

De façon générale, le vote par internet est ouvert du vendredi au mercredi (12h, heure de Paris), et le vote à l'urne a lieu le samedi ou le dimanche qui suit, selon le fuseau horaire de la circonscription. Le dépouillement final, agrégeant la totalité des bulletins issus des différentes modalités, commence dès la clôture du vote à l'urne de la circonscription se terminant le plus tard, à savoir celle de Dakar (le dimanche à 21h, heure de Paris).

Quelque soit le type d'élection, le présent document aborde uniquement la modalité de vote par internet : la consolidation des différentes modalités de vote et la désignation finale des élus ne sont pas traitées.

Gestion des deux tours. Les élections législatives pouvant comporter deux tours, nous précisons que la solution prévoit d'organiser les deux tours de manière parfaitement indépendante. Entre les deux tours, la base de données est entièrement remise à zéro et toutes les opérations d'import ainsi que les différentes cérémonies sont effectuées de nouveau. Les clefs publiques de chiffrement et de signature utilisées lors du tour 1 par la solution de vote ne seront donc pas valables pour le tour 2.

I.2 Les acteurs et leurs responsabilités

Notre protocole fait intervenir de nombreux acteurs, dont certains cumulent plusieurs responsabilités. Dans cette section, nous listons les principaux acteurs, explicitons leur rôle dans le protocole et précisons nos hypothèses de confiance.

I.2.1 Désignation des acteurs

L'organisateur. Le MEAE est l'entité organisatrice du scrutin. À ce titre, il est de loin l'acteur ayant le plus de responsabilités : il fournit les listes électorales, la liste des candidats (ou des listes de candidats) et les locaux dans lesquels se déroulent les cérémonies. Il se charge de la communication avec les électeurs, choisit le fournisseur de la solution de vote (ainsi que le tiers vérificateur) et finance l'opération. De plus, le MEAE fournit la plupart des systèmes d'information intervenant au cours de l'élection ; en d'autres termes, il se charge de l'hébergement de la solution de vote.

Parmi les systèmes d'information placés sous la responsabilité du MEAE, les suivants jouent un rôle important dans notre protocole.

- Le SI CODE intervient lors de la génération des secrets d'authentification. Il a pour responsabilité de centraliser et de reformater les données d'entrée de l'élection (liste électorale, candidats *etc.*). De plus, il génère les mots de passe des électeurs (sous forme chiffrée).
- Le SI VOTE, ou serveur de vote, intervient tout au long de la phase de vote. Il gère les demandes de renouvellement d'identifiant et de mot de passe, l'authentification des électeurs et l'insertion des bulletins dans l'urne. De plus, il est responsable de la liste d'émargement et de l'accumulation des bulletins.
- Le SI RESULTAT génère la clef publique de chiffrement des suffrages et effectue le calcul des résultats lors du dépouillement. À cette occasion, il génère les procès-verbaux associés.

Le fournisseur de solution. La société Voxaly-Docaposte est le fournisseur de la solution de vote par internet. Elle est responsable de la conception et de l'implémentation du protocole de vote et fournit le code applicatif correspondant (pour le SI CODE, le SI VOTE et le SI RESULTAT), ainsi que des données de paramétrage. Elle joue également un rôle de conseil et de pilotage tout au long de l'opération.

Le tiers vérificateur. Le tiers vérificateur est un acteur indépendant de Voxaly et extérieur au MEAE (et, plus généralement, de l'administration publique). Comme son nom l'indique, il intervient principalement pour effectuer des vérifications, mais ses responsabilités ne se limitent pas à cela :

1. Lors de la génération des secrets d'authentification, il fournit et opère le SI CODE_{B} qui génère les identifiants (sous forme chiffrée).
2. Lors de la phase de vote, il récupère de manière asynchrone la liste des empreintes des bulletins.
3. Lors de la phase de vote, il héberge et opère un service web permettant aux électeurs de vérifier la présence de leur bulletin dans l'urne, ainsi que de la validité de leur accusé de réception.
4. Après la clôture, il vérifie la validité et la légitimité des bulletins dans l'urne, et s'assure de la cohérence de cette dernière avec l'ensemble des empreintes reçues.

5. Après le dépouillement, il recalcule les accumulations et vérifie les preuves liées au bon dépouillement de l'urne.

Le tiers vérificateur est par ailleurs responsable de l'écriture du code applicatif destiné à remplir ses différentes responsabilités, ainsi que de l'infrastructure opérationnelle associée.

Le fournisseur d'identité. France identité numérique (FIN) est le fournisseur d'identité utilisé afin de proposer une méthode d'authentification alternative aux électeurs. Lorsque les électeurs s'authentifient via FIN, cette dernière est responsable de leur authentification et se porte garante de l'identité de l'électeur.

Le bureau de vote électronique (BVE). Composé d'élus et de représentants de l'administration, il préside la plupart des cérémonies, proclame les résultats et veille au suivi de la procédure. De plus, le bureau de vote a un rôle de surveillance et peut effectuer certains contrôles d'intégrité. Enfin, il a pour responsabilité de choisir et de conserver de manière confidentielle les phrases secrètes qui permettent de procéder au dépouillement. En cas d'incident impactant le vote par internet, le BVE est le seul décisionnaire quant aux mesures à prendre (*e.g.*, interrompre ou suspendre le scrutin).

Les prestataires d'envoi de courriel et de SMS. Afin de communiquer leurs secrets d'authentification aux électeurs, nous faisons intervenir quatre prestataires différents (deux principaux et deux de secours). Ils ont pour responsabilité de déchiffrer les fichiers contenant les secrets d'authentification et de transmettre leurs secrets aux électeurs.

Les électeurs. Les électeurs s'authentifient sur la plateforme, sélectionnent une option de vote, soumettent leur bulletin, téléchargent leur accusé de réception et utilisent le service déployé par le tiers vérificateur pour vérifier la présence de leur bulletin dans l'urne ainsi que la validité de leur accusé de réception.

I.2.2 Nos hypothèses de confiance

Notre protocole a été conçu pour garantir un certain nombre de propriétés, présentées en section I.5. Pour cela, il s'appuie sur des *hypothèses de confiance*, c'est-à-dire qu'il considère que certains acteurs sont honnêtes quand il s'agit d'effectuer certaines tâches. Prises à l'envers, ces hypothèses permettent de déterminer les points de défaillance, qui sont les sous-ensembles d'acteurs qui, en œuvrant de concert dans ce but, peuvent remettre en cause les propriétés de sécurité.

I.2.2.a Les points de défaillance uniques

Un point de défaillance unique est un acteur qui, en s'écartant volontairement du protocole, peut porter atteinte à l'une des propriétés de sécurité, ce sans avoir besoin de collaborer avec un complice. Dans notre étude, nous avons identifié un certain nombre d'acteurs correspondant à ce critère.

Le MEAE. Le MEAE est l'acteur qui cumule le plus de responsabilités. À ce titre, il n'est pas étonnant qu'il constitue un point de défaillance unique. Le fait qu'un ministère entier soit compromis ou corrompu nous parait improbable et difficile à anticiper : dans la pratique, le ministère est en fait constitué de multiples acteurs. Dans notre protocole, nous faisons confiance au ministère pour deux points cruciaux.

- Le ministère fournit les référentiels listant les candidats et les électeurs (ce qui comprend les adresses mail et les numéros de téléphone des électeurs).
- Le ministère héberge le SI CODE, le SI VOTE et le SI RESULTAT. À ce titre, il est garant de leur cloisonnement et de leur sécurisation.

Si le ministère venait à modifier illégitimement la liste électorale ou à permettre une collaboration malhonnête entre le SI CODE et le SI VOTE, alors la légitimité des bulletins dans l'urne ne serait plus assurée. En d'autres termes, le MEAE dans sa globalité peut théoriquement effectuer un bourrage d'urne, mais pas le SI VOTE pris individuellement.

Si le ministère interférait malicieusement avec le SI RESULTAT, et le SI VOTE, alors la stricte confidentialité du vote ne serait plus assurée.

Si le ministère parvenait à modifier le comportement du SI VOTE, le secret du vote et la sincérité du scrutin ne serait plus garantis.

France Identité Numérique. FIN est considérée honnête pour ce qui est de l'authentification des électeurs. De plus, le canal de communication établi entre le poste de l'électeur et FIN lors du protocole d'authentification est supposé sécurisé. Si FIN ou le canal susmentionné devait être compromis, la légitimité des bulletins dans l'urne ne serait plus garantie.

Les postes des électeurs. Nous désignons par « poste de l'électeur » l'ensemble des appareils électroniques que l'électeur utilise pour voter (par exemple, un téléphone ou un ordinateur) ainsi que leur environnement logiciel, ce qui inclut le système d'exploitation et le navigateur internet. Le poste de l'électeur est supposé honnête pour ce qui est du secret du vote (il n'enregistre pas l'option sélectionnée par l'électeur), du chiffrement *tel quel* (il envoie un bulletin qui contient le choix effectué par l'électeur, et pas un autre) et de la légitimité des bulletins (il n'effectue pas de hameçonnage sur les secrets d'authentification saisis par les électeurs).

I.2.2.b Les hypothèses de non collusion

La collusion de plusieurs acteurs correspond à une collaboration malhonnête, c'est-à-dire une déviation du protocole qui se fait de manière conjointe et volontaire.

La connaissance simultanée d'un identifiant et d'un mot de passe. Parmi les prestataires d'envoi de courriel et de SMS, le SI CODE, le SI CODE_{B} et le SI VOTE, on suppose qu'aucune paire de deux acteurs ne collabore pour réunir les deux types de secrets d'authentification pour un même électeur. De plus, on suppose qu'aucun acteur ne parvient à compromettre les deux canaux de communication utilisés pour envoyer ou renvoyer leurs secrets d'authentification aux électeurs, de manière à avoir la connaissance d'un identifiant

et d'un mot de passe pour le même électeur. Si l'une de ces hypothèses devait être bafouée, la légitimité des bulletins dans l'urne ne serait plus garantie.

Le tiers vérificateur. On suppose que le SI VOTE n'entre pas en collusion avec le tiers vérificateur. Dans le cas contraire, de nombreuses propriétés de vérifiabilité ne seraient plus garanties, comme par exemple

- La vérifiabilité individuelle : le serveur de vote pourrait ne pas insérer certains bulletins dans l'urne, et le tiers répondre positivement aux demandes des électeurs alors que leur bulletin n'est pas dans l'urne ;
- La légitimité des bulletins dans l'urne : le serveur de vote pourrait ajouter des bulletins illégitimes dans l'urne, et le tiers vérificateur ne pas signaler leur présence ;
- La cohérence entre le résultat du dépouillement et l'urne : le SI VOTE pourrait fournir au SI RESULTAT des accumulations n'étant pas strictement égales au résultat de l'accumulation des bulletins dans l'urne, et le tiers s'abstenir de signaler cette incohérence.

Pour des raisons similaires, on suppose que le SI RESULTAT n'entre pas en collusion avec le tiers vérificateur. Dans le cas contraire, le SI RESULTAT pourrait annoncer un résultat incohérent avec le dépouillement des accumulations, et le tiers s'abstenir de signaler l'incohérence.

I.2.2.c Quelques scénarios d'attaque

Afin d'illustrer l'importance de nos hypothèses de confiance, nous proposons quelques scénarios d'attaque qui pourraient survenir si une hypothèse devait être bafouée..

Collaboration entre SI VOTE **et** SI CODE**.** Nous commençons par un scénario dans lequel un attaquant (*e.g.*, le MEAE) parviendrait à compromettre à la fois le SI CODE et le SI VOTE, par exemple en installant un logiciel espion, en interférant avec la génération de nombres pseudo-aléatoires ou en modifiant le code applicatif exécuté. Ce faisant, l'attaquant pourrait connaître les mots de passe de tous les électeurs, car ils sont générés par le SI CODE. Par ailleurs, l'attaquant pourrait également apprendre les identifiants des électeurs qui effectuent une demande de renouvellement d'identifiant. En effet, lors du renouvellement d'un identifiant, c'est le SI VOTE qui génère un nouvel identifiant qui annule et remplace l'identifiant précédent, puis l'envoie à l'électeur. À noter que si un attaquant prend le contrôle du SI VOTE (par exemple en modifiant le code exécuté), il pourrait théoriquement provoquer des renouvellements d'identifiant non sollicités, et donc apprendre un grand nombre de couples d'identifiants et de mots de passe. Avec ces informations, l'attaquant pourrait générer des bulletins et les signer de façon en apparence légitime, et donc porter atteinte à la sincérité du résultat.

Contre-mesures. La première contre-mesure est de rendre ce scénario improbable, ce grâce à un cloisonnement entre le SI CODE et le SI VOTE ainsi que l'utilisation d'environnements sécurisés (voir la section I.2.3). Une deuxième contre-mesure est la surveillance du nombre de demandes de renouvellement, notamment d'identifiants, ce via un service dédié dans l'application d'une part, et via les vérifications effectuées par le tiers vérificateur d'autre part. En effet, pour chaque émargement, notre protocole permet au tiers vérificateur

de déterminer si l'électeur correspondant a fait une demande de renouvellement (et, dans ce cas, s'il s'agit d'un renouvellement d'identifiant ou de mot de passe). Enfin, pour rendre plus facilement détectable ce scénario de collusion ente le SI CODE et le SI VOTE, nous avons confié la génération des identifiants au SI CODE_{B}, conçu et opéré par le tiers vérificateur. En effet, nous avons constaté que les renouvellements légitimes sont plus nombreux pour les mots de passe (envoyés par SMS) que pour les identifiants (envoyés par courriel). Ainsi, ce scénario de collusion sera plus facile à détecter du fait d'un nombre anormalement élevé de renouvellements d'identifiants.

Collaboration entre SI VOTE **et** SI RESULTAT**.** Nous considérons maintenant un attaquant qui parviendrait à compromettre à la fois le SI VOTE et le SI RESULTAT (*e.g.*, le MEAE), par exemple en installant un logiciel espion, en interférant avec la génération de nombre pseudo-aléatoires (pour le SI RESULTAT) ou en modifiant le code exécuté. À noter que d'autre types d'attaques sont possibles pour le SI VOTE, comme par exemple la création et / ou l'exploitation d'une rupture de chiffrement TLS ou l'accès en lecture à la base de données contenant l'urne électronique.

En compromettant le SI RESULTAT, l'attaquant pourrait apprendre la clef privée permettant le déchiffrement des bulletins. En compromettant le SI VOTE, l'attaquant pourrait obtenir des bulletins et l'identité des électeurs les ayant soumis, ce qui lui permettrait de briser le secret du vote.

Contre-mesure. Ce scénario est rendu improbable du fait de la difficulté de la mise en œuvre d'une telle attaque (voir la section I.2.3), notamment en comparaison au gain que pourrait en tirer l'attaquant.

Compromission du client de vote. Nous considérons cette fois-ci un attaquant (*e.g.*, le MEAE) capable de modifier le comportement du SI VOTE et / ou d'exploiter une rupture de chiffrement TLS. Ce faisant, l'attaquant pourrait envoyer un client de vote modifié au poste de l'électeur, ce qui pourrait lui permettre de récupérer ses secrets d'authentifications via du hameçonnage (et donc de voter à sa place), d'apprendre le choix de l'électeur et / ou de modifier, à son insu, le contenu de son bulletin.

Contre-mesure. Outre la difficulté de mise en place de cette attaque, nous notons que le code source du client de vote est public [Vox26], ce qui permettra aux électeurs de vérifier que le code du client de vote correspond à celui fourni par Voxaly.

I.2.3 Sur la sécurité de l'hébergement

L'hébergement et l'infogérance de la solution de vote sont assurés sous l'entière responsabilité du MEAE, Voxaly ne disposant d'aucun accès aux environnements déployés. À titre informatif, nous donnons quelques éléments, non exhaustifs, portant sur les mesures de sécurité dont nous avons connaissance.

Le SI CODE et le SI RESULTAT sont des systèmes fonctionnant en total autonomie, sans aucune connexion réseau. Ils ne sont actifs que pendant de courtes périodes (avant le

scrutin pour la génération des différents secrets et à la clôture pour le dépouillement), et toujours sous la surveillance du BVE.

Lorsqu'ils ne sont pas utilisés, ils sont conservés dans un coffre-fort placé sous vidéo-surveillance, et l'accès à la salle est limité et tracé.

Le SI VOTE est connecté à internet afin de récolter les votes et bénéficie d'une exploitation et d'une surveillance renforcées par les équipes techniques du MEAE. En particulier, des mesures d'audit, de protection et de supervision sont mises en œuvre pour protéger le SI VOTE des attaques externes et limiter et tracer les accès légitimes par les équipes d'exploitation du MEAE et de gestion de l'élection, la supervision étant faite par une équipe distincte de l'équipe d'exploitation.

I.3 Présentation des différentes phases

Un protocole de vote par internet possède généralement trois phases : la *mise en place* se fait en amont du scrutin et permet (entre autres) de générer les secrets d'authentification ainsi que la clef publique de chiffrement ; le *vote* permet aux électeurs de soumettre leur bulletin par internet ; le *dépouillement* permet de déterminer le résultat du scrutin.

I.3.1 La mise en place

Dans notre protocole, la phase de *mise en place* s'appelle l'avant-vote, ou la phase avant ouverture. Comme dit plus haut, elle permet la génération des secrets d'authentification et leur envoi aux électeurs d'une part, et d'autre part de la clef publique de chiffrement des suffrages.

La génération des secrets d'authentification. La génération des identifiants et des mots de passe se fait de façon symétrique et indépendante, sur deux machines distinctes, le SI CODE et le SI CODE_{B}. (Voir la section I.2.3 qui décrit l'environnement sécurisé du SI CODE.) Chaque machine produit des informations chiffrées à destination d'un prestataire d'envoi (courriel ou SMS), ainsi que des informations destinées à l'import dans le SI VOTE. Seul le prestataire correspondant possède la clef privée permettant le déchiffrement des informations ainsi générées ; il s'en sert pour déchiffrer les secrets puis les transmet aux électeurs. Les informations destinées au SI VOTE ne révèlent rien sur les secrets générés mais permettent d'effectuer l'authentification des électeurs et interviennent dans la vérification de la légitimité des bulletins.

Les identifiants et les mots de passe sont créés de manière à pouvoir être utilisés en amont de chaînes de dérivation. Lors de leur saisie, le client de vote suit ces chaînes afin de constituer une clef privée qui lui permettra de signer le bulletin.

Les secrets sont envoyés aux électeurs par deux prestataires indépendants qui utilisent chacun un canal différent, les informations de contact des électeurs (leur adresse courriel et leur numéro de téléphone) étant renseignées par l'organisateur du scrutin.

La génération de la clef de chiffrement. La génération de la clef de chiffrement, et surtout de la clef privée associée, se fait sur le SI RESULTAT. (Voir la section I.2.3 qui décrit l'environnement sécurisé du SI RESULTAT.) Ce dernier utilise un schéma de partage de secret pour découper la clef privée en différents fragments, chacun étant laissé en la seule possession d'un membre du bureau de vote électronique (BVE). La clef de déchiffrement n'est pas enregistrée, et les fragments de secrets ne sont enregistrés en clair. À la place, il sont enregistrés sous une forme chiffrée, et le déchiffrement de chaque fragment n'est possible qu'à l'aide d'une phrase secrète choisie, saisie et conservée par le membre du bureau de vote auquel le fragment est attribué . Les fragments sont générés de telle sorte qu'il existe un *seuil* en-dessous duquel il n'est pas possible de reconstituer la clef de déchiffrement. En d'autres termes, aucun déchiffrement n'est possible sans l'accord d'un certain nombre de membres du BVE. Ce seuil est tout de même inférieur au nombre total de membres, de manière à ce que le dépouillement puisse avoir lieu même si un ou plusieurs d'entre eux devaient être indisponibles.

I.3.2 La phase de vote

Durant la phase de vote, nous recensons principalement deux type d'événements : l'authentification des électeurs et la soumission des bulletins. L'authentification d'un électeur peut être précédée par une demande de renouvellement de l'identifiant ou du mot de passe, et la soumission d'un bulletin peut être suivie par une opération de vérification individuelle.

Authentification des électeurs. Afin d'augmenter le taux de participation et de faire face aux situations dans lesquelles un électeur n'aurait pas renseigné une adresse courriel et/ou un numéro de téléphone valide, notre solution de vote propose deux modes d'authentification : l'authentification par identifiant et mot de passe et l'authentification par France Identité Numérique (FIN). Les identifiants et les mots de passe ne sont pas communiqués tels quels au serveur : à la place, le client de vote envoie des éléments pré-hachés. Cela évite que le serveur apprenne les secrets d'identifications, qui peuvent être utilisés afin de soumettre un bulletin légitime. Quant à FIN, elle effectue une authentification de niveau élevé (au sens eIDAS [Jou14]) qui garantit que l'électeur est en possession d'un titre d'identité et du code PIN associé.

Ces deux moyens d'authentification sont considérés comme fiables et limitent grandement les possibilités d'usurpation d'identité. Afin de ne pas interdire l'accès au vote aux électeurs ayant perdu ou non reçu l'un de leur secret d'authentification (identifiant ou mot de passe), il existe un mécanisme de **renouvellement** qui permet aux électeurs de demander à ce qu'un secret soit regénéré et renvoyé. Ce processus fait lui-même l'objet d'une authentification (voir la section III.1).

Soumission d'un bulletin. Le choix de l'électeur (son suffrage) est chiffré côté navigateur à l'aide de la clef publique de chiffrement des suffrages, ce qui donne un bulletin. Ce chiffrement protège la confidentialité du choix de l'électeur durant toute la durée de vie du bulletin. Il s'accompagne de preuves à divulgation nulle de connaissance qui permettent au serveur de s'assurer que le bulletin contient un choix valide, ce sans révéler le choix. Les

bulletins sont émis signés, ce qui renforce leur intégrité durant leur transport via le réseau internet, mais aussi pendant leur stockage dans l'urne électronique. De plus, cette signature est utilisée pour contrôler la légitimité du bulletin et contrecarre les tentatives de bourrage d'urne, y compris par le serveur de vote (voir la section III.3.2).

Après la soumission du bulletin, le serveur vérifie la validité des preuves et de la signature et effectue le contrôle de l'émargement. En cas de succès, le bulletin est inséré dans l'urne, l'électeur est émargé et le serveur envoie un cachet au poste de l'électeur. L'électeur peut alors télécharger son accusé de réception, ce qui provoque l'enregistrement sur son appareil d'un document PDF. Ce dernier permet de contrôler la présence du bulletin dans l'urne ainsi que la validité du cachet.

I.3.3 La phase après clôture

Après la clôture du scrutin, les bulletins et les émargements sont exportés et mis sous scellés via des prises d'empreintes. Les bulletins sont ensuite accumulés en prévision du dépouillement, qui est lancé quelques jours plus tard. L'accumulation a lieu sur le SI VOTE, et le dépouillement sur le SI RESULTAT, à partir des bulletins accumulés. Cela garantit la stricte séparation des bulletins et de la clef de déchiffrement : seules les accumulations sont déchiffrées, ce qui signifie qu'aucun bulletin n'est déchiffré individuellement et qu'aucun dépouillement partiel n'est possible. Le dépouillement s'effectue en séance, sous le contrôle du bureau de vote. Son résultat est validé par le tiers vérificateur, qui s'appuie pour cela sur des preuves cryptographiques et des empreintes préalablement collectées.

I.4 Scellements et contrôles d'intégrité

Afin de renforcer la confiance dans notre protocole, des mécanismes de scellement et de contrôle d'intégrité permettent de vérifier l'absence d'altérations frauduleuses. Pour cela, nous distinguons notamment les éléments statiques et dynamiques.

Ces deux types d'éléments font l'objet de contrôles automatiques par l'application elle-même, par des scripts indépendants et des outils systèmes. Dans le cas où une modification serait constatée, des alertes sont levées de manière automatique et systématique, puis envoyées au bureau de vote. Ces contrôles sont effectués régulièrement, selon une fréquence aléatoire.

En plus des contrôles automatiques, le bureau de vote électronique (BVE) dispose d'un accès autonome lui permettant de déclencher des contrôles.

Intégrité statique. Les éléments statiques n'ont pas vocation à évoluer au cours du scrutin. Ils se déclinent principalement en trois catégories : les données (la liste électorale, les candidats *etc.*), le code de l'application (y compris le paramétrage et les scripts SQL) et les données d'infrastructure (fichiers de configuration, intergiciels, certificats *etc.*). Pour les éléments statiques, une empreinte initiale est prise avant le scrutin et est stockée sur un support stable et non modifiable ; elle est également communiquée au BVE, ce par l'intermédiaire d'un procès-verbal.

Intégrité dynamique. Les éléments dynamiques sont ceux qui subissent naturellement des modifications tout au long du scrutin, comme la liste d'émargement et l'urne électronique. Pour les protéger contre des modifications frauduleuses, nous effectuons des scellements par blocs, chaque bloc faisant l'objet d'une prise d'empreinte. Ainsi, chaque élément est protégé en intégrité grâce à des chaînes de blocs qui sont ultimement scellées et horodatées par un prestataire de services qualifié (en conformité avec la spécification européenne [Eur02]).

En plus du chaînage par blocs, les empreintes des bulletins sont externalisées dans le webservice du tiers vérificateur, ce grâce à une interface applicative. Cela lui permet de détecter toute altération des bulletins en amont de l'accumulation.

I.5 Les propriétés de sécurité de notre protocole

Notre protocole de vote par internet a été conçu pour répondre aux objectifs de sécurité de la commission nationale de l'informatique et des libertés (*i.e.* la CNIL) et aux exigences du MEAE, en accord avec les conseils de l'agence nationale de la sécurité des systèmes d'informations (*i.e.* l'ANSSI). Les principales propriétés ciblées sont regroupées dans la liste suivante (non exhaustive).

- Le **secret du vote** correspond à la confidentialité du choix de chaque électeur. Elle est assurée par un chiffrement du choix de l'électeur, qui s'effectue dès la création du bulletin par le client de vote. Une fois le bulletin soumis, aucun lien ne peut être établi entre un votant et l'expression de son vote. Aucun résultat anticipé ou partiel ne peut être obtenu et un procédé d'anonymisation est utilisé afin de protéger le lien entre l'identité de l'électeur et son bulletin.
- L'**équité** entre les candidats et les électeurs signifie qu'aucun individu n'est privilégié par rapport aux autres. Aucun candidat ou liste de candidats n'est mis en avant et nous n'influençons pas le choix des électeurs. De plus, chaque électeur ne peut voter qu'une fois, et des preuves cryptographiques garantissent que le choix effectué est un choix valide, ce sans révéler le choix.
- La **légitimité** porte sur le fait que le vote n'est accessible qu'aux électeurs inscrits sur les listes électorales. Pour cela, nous mettons en place des moyens d'authentification forts qui luttent contre les éventuelles usurpations d'identité, ainsi que des contrôles qui permettent de détecter les tentatives de bourrage d'urne.
- L'**intégrité** correspond à l'aspect inaltérable des éléments critiques du protocole de vote. Le code applicatif fait l'objet d'audits et de contrôles d'intégrité par des experts indépendants, et l'intégrité des bulletins est protégée par un schéma de signature ainsi que par des empreintes qui sont externalisées par un tiers indépendant. L'intégrité des émargements ainsi que d'autres données est également protégée par des prises d'empreintes et des contrôles réguliers, aussi bien automatiques que manuels.
- La **sincérité** du résultat vis-à-vis de la volonté exprimée des votants est protégée par un mécanisme de vérifiabilité qui permet de contrôler la validité du résultat par rapport aux bulletins présents dans l'urne.
- La **transparence de l'urne** correspond à la possibilité pour chaque électeur de vérifier que son bulletin a bien été déposé dans l'urne qui sera utilisée lors du dépouillement.

Elle est offerte par un web-service développé, opéré et hébergé par le tiers vérificateur.

Mise en œuvre partielle de la vérification individuelle. Dans le cas d'un vote papier, l'électeur place lui-même son choix dans une enveloppe et dépose lui-même son enveloppe dans l'urne, sauf cas particuliers. Dans un vote par internet, l'analogue de la mise sous enveloppe est le chiffrement du suffrage, effectué par le client de vote, et le dépôt dans l'urne est effectué par le serveur de vote. Du fait que l'électeur n'effectue pas lui-même ces opérations, il pourrait avoir moins de garanties quant au cycle de vie de son bulletin, ce qui impacterait la sincérité du scrutin.

Pour renforcer la confiance de l'électeur dans les protocoles de vote par internet, la littérature académique a introduit la notion de *vérification individuelle*, qui consiste à offrir à l'électeur des moyens de vérifier que son choix a bien été chiffré par son client de vote (chiffrement *tel quel*, ou *cast-as-intended*), et que le bulletin a bien été pris en compte par le serveur de vote (enregistrement *tel quel*, ou *recorded as cast*).

Pour ce qui est du chiffrement *tel quel*, la littérature académique propose de nombreuses approches, au point que l'on peut en faire une classification [MZR+21]. En plus de ne pas avoir de solution consensus, cette problématique fait encore l'objet de recherches actives et n'est donc pas considérée comme résolue ; un exemple récent peut être trouvé dans [BCC+22, CGGL24]. Au moment de la rédaction de ces lignes (avril 2025), nous considérons qu'aucune des solutions existantes n'est satisfaisante, que ce soit parce que les garanties sont insuffisantes, parce que la mise en place est trop complexe ou du fait d'un trop grand impact sur l'expérience utilisateur. Pour ces raisons, notre protocole n'offre pas la possibilité de vérifier le chiffrement *tel quel*. Néanmoins, le code source de la partie cliente est publié[Vox26].

Contrairement à la vérification du chiffrement *tel quel*, la vérification de l'enregistrement *tel quel* (c'est-à-dire la transparence de l'urne) fait partie des objectifs de sécurité retenus par la CNIL lors de sa délibération de 2019 [Com19, Objectif de sécurité n°2-07] et est proposé dans notre solution de vote, ce via le service du tiers vérificateur.

I.6 Les primitives cryptographiques

En complément des informations génériques sur notre protocole, nous donnons quelques éléments techniques communs à tout le protocole. Dans la mesure où cette version du document ne fournit aucun détail d'implémentation ni pseudo-code, cette section y est moins fournie que dans les autres versions.

I.6.1 Le hachage cryptographique

Une fonction de hachage est une fonction déterministe de $\{0,1\}^*$ dans $\{0,1\}^{2\lambda}$, où λ est un paramètre de sécurité. Elle permet d'associer une *empreinte* de taille fixe (typiquement, 32 octets) à des éléments de taille arbitraire, potentiellement très volumineux. Les fonctions de hachage cryptographiques possèdent la très importante propriété de *résistance aux collisions*, c'est-à-dire qu'il est considéré comme impossible de trouver deux entrées différentes, x et y, telles que $\text{hash}(x) = \text{hash}(y)$, où hash est la fonction de hachage. Cette propriété est entre

autre utilisée afin de détecter les éventuelles modifications des données : si une empreinte h d'un élément x a été prise à un instant t, on peut s'assurer à l'instant t' que x n'a pas été modifié en recalculant son empreinte et en vérifiant que $h = \text{hash}(x)$, ce qui nécessite de conserver l'empreinte de manière sécurisée.

Les fonctions de hachage sont omniprésentes dans les protocoles cryptographiques, et notre protocole ne fait pas exception. En plus de les utiliser pour générer des empreintes et contrôler l'intégrité des données, nous les utilisons dans nos primitives de signatures et nos preuves à divulgation nulle de connaissance. Du fait de l'importance d'une telle primitive et de l'utilisation standard que nous en faisons, nous utilisons sha256 [Fed15].

I.6.2 La cryptographie sur courbe elliptique

La cryptographie sur courbe elliptique définit une grande quantité d'algorithmes et de primitives dont la sécurité repose généralement sur la difficulté de calculer un logarithme discret. Dans notre solution, nous utilisons la courbe edwards25519 [LHT16], qui possède le même niveau de sécurité que Curve25519, elle-même recommandée par la NIST [Nat23] et l'ANSSI [Age21]. Nous avons choisi cette courbe sur les conseils d'experts en logarithme discret du CNRS, que nous avons consultés à ce sujet. Dans ce document, lorsque nous parlons de l'*ordre* de la courbe elliptique, nous faisons référence au nombre premier q défini dans l'équation (1). Mathématiquement, la courbe edwards25519 est en fait le sous-groupe d'ordre q du groupe $\mathcal{G}$ des points $P = (x, y) \in \mathbb{F}_p^2$ tels que $y^2 - x^2 = 1 + dx^2y^2$, où $p = 2^{255} - 19$, où $\mathbb{F}_p$ est le corps à p éléments et où d est donné dans l'équation (2) (en hexadécimal). Les valeurs de x et y sont alors les coordonnées *affines* de P. La valeur de q donne à la courbe edwards25519 un niveau de sécurité estimé à 126 bits de sécurité ; les 2 bits de sécurité manquant par rapport aux 128 bits de sécurité généralement recommandés sont sans conséquence.

$$q = 2^{252} + 27742317777372353535851937790883648493 \quad (1)$$

$$d = \texttt{52036cee2b6ffe738cc740797779e89800700a4d4141d8ab75eb4dca135978a3} \quad (2)$$

La RFC [JL17] donne une convention de représentation des points de la courbe sous forme de chaînes de 32 octets. Sauf indication du contraire, nous encodons les points de cette manière. Lorsqu'on décode une chaîne de 32 octets en suivant cette convention, on peut soit rencontrer une erreur (l'encodage est invalide), soit récupérer un point P dont les coordonnées affines x et y respectent l'équation de la courbe. Cependant, P n'est pas nécessairement dans le sous-groupe d'ordre q. En effet, $\mathcal{G}$ possède un sous-groupe cyclique d'ordre 8, représenté dans la figure I.1. On peut trouver les points de ce sous-groupe en cherchant des points de coordonnée (x, y) tels que $dx^4 - 2x^2 = 1$ et $y = ux$, où $u \in \mathbb{F}_p$ est tel que $u^2 + 1 = 0$. Du fait de l'existence de ce sous-groupe, il peut être intéressant, en plus de contrôler qu'un encodage d'un point P est valide selon la RFC [JL17] (c'est-à-dire que P vérifie l'équation de la courbe), de vérifier que $P^q = (0, 1)$, c'est-à-dire que P appartient bien au sous-groupe d'ordre q.

```
xxdqcD1N2E-6PAt2DRBnDyogU_osOczGTsf9d5KsA3o
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAIA
JuiVj8KyJ7BFw_SJ8u-Y8NXfrAXTxjM5sTgCiG1T_AU
7P____________________________________38
JuiVj8KyJ7BFw_SJ8u-Y8NXfrAXTxjM5sTgCiG1T_IU
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
xxdqcD1N2E-6PAt2DRBnDyogU_osOczGTsf9d5KsA_o
AQAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
```

FIGURE I.1 – Représentation en base 64 du sous-groupe cyclique d'ordre 8 de $\mathcal{G}$, l'ensemble des points de $\mathbb{F}_p^2$ respectant l'équation de la courbe edwards25519, où $p = 2^{255} - 19$.

I.6.3 Le chiffrement ElGamal exponentiel

Le chiffrement ElGamal [Tah84] est un système de chiffrement à clef publique dont la sécurité repose sur le problème décisionnel de Diffie-Hellman, lui-même basé sur le problème du logarithme discret. Étant donné un groupe G (ici, la courbe elliptique edwards25519 ; voir section I.6.2) et un générateur g, le chiffrement d'un point $m \in G$ à l'aide de la clef publique $\mathsf{pk}_{\mathsf{enc}} \in G$ se fait en tirant un nombre aléatoire r puis en calculant $\alpha = g^r$ et $\beta = m{\mathsf{pk}_{\mathsf{enc}}}^r$. Le chiffré est alors le couple (α, β). Pour déchiffrer ce couple à l'aide de la clef privée $\mathsf{sk}_{\mathsf{dec}}$ telle que $\mathsf{pk}_{\mathsf{enc}} = g^{\mathsf{sk}_{\mathsf{dec}}}$, on utilise l'identité $m = \beta\alpha^{-\mathsf{sk}_{\mathsf{dec}}}$.

Dans notre solution, nous utilisons le chiffrement ElGamal afin de chiffrer des bits $b \in \{0, 1\}$ de la manière suivante : si $b = 0$, on chiffre l'élément neutre (g^0) et si $b = 1$, on chiffre le point g (g^1). Cela nous permet d'exploiter la propriété homomorphique du chiffrement ElGamal et de multiplier les chiffrés entre eux lors de la phase d'accumulation. Cette façon d'utiliser le chiffrement ELGamal est connue dans la littérature comme le chiffrement ElGamal *exponentiel*, car le bit b est chiffré dans un exposant (en particulier, le déchiffrement nécessite de calculer un logarithme discret, ce qui est faisable en pratique car le logarithme en question est petit).

I.6.4 La signature électronique

La signature électronique est une primitive cryptographique à clef publique permettant de garantir l'authenticité et l'intégrité des données. Elle repose sur l'existence d'une paire de clefs $(\mathsf{sk}, \mathsf{pk})$, où pk est une clef publique (la clef de *vérification*) pouvant être distribuée et exposée sans risque tandis que sk est une clef privée (la clef de *signature*). La sécurité de cette primitive repose d'une part sur le fait qu'une seule et unique entité, l'entité *signataire*, est en possession de la clef privée, et d'autre part que la connaissance de cette clef est nécessaire pour créer une signature valide. Étant donné un message m, le signataire peut utiliser son secret et calculer une signature σ. Cette signature peut ensuite être vérifiée grâce à un algorithme de vérification qui permet de contrôler la validité du triplet (pk, σ, m). Lorsque la signature est valide, la personne l'ayant vérifiée a la garantie que le message m a été signé par le signataire, et que m n'a pas été modifié entre-temps.

Dans notre solution, nous utilisons (entre autres) la signature de Schnorr [Sch89], qui a fait l'objet d'une preuve de sécurité dans [PS96]. Notre algorithme de signature utilise la

courbe elliptique edwards25519, comme indiqué dans la section I.6.2.

I.6.5 Les preuves à divulgation nulle de connaissance

Une preuve à divulgation nulle de connaissance (PDN) est un objet cryptographique permettant à un prouveur de convaincre un vérifieur qu'il (le prouveur) possède un secret qui vérifie certaines propriétés. Dans notre solution, les PDN interviennent à de nombreux endroits. Par exemple, nous utilisons des PDN pour permettre au client de vote de prouver que le bulletin contient un choix valide (voir la section III.3.1), ce sans révéler le choix.

I.6.5.a La preuve de bon mélange

Dans notre solution, nous utilisons un mécanisme de mélange et de chiffrement vérifiable, basé sur une variante de la preuve de bon mélange de Terelius et Wikström [Wik09, TW10]. Cette variante est décrite dans [HKLD17, Section 5.5].

I.6.5.b La preuve d'exponentiation commune

Une PDN récurrente dans notre solution est la preuve d'exponentiation commune, qui consiste à prouver que deux listes de points sont l'image l'une de l'autre par un morphisme d'exponentiation. En d'autres termes, il s'agit de prouver, étant donnés $a_0, \cdots, a_n$ et $b_0, \cdots, b_n$, qu'il existe un scalaire sk tel que $b_i = a_i^{\mathsf{sk}}$ pour tout i. Cela peut intervenir dans une preuve de déchiffrement d'une part (sk est alors la clef de déchiffrement), mais aussi d'anonymisation (l'exponentiation sert alors de fonction pseudo-aléatoire, et doit être combinée à une preuve de bon mélange). Pour générer une telle preuve, nous utilisons une généralisation de la preuve de Chaum-Pedersen [CP92].

Chapitre II

La phase de mise en place

La phase de mise en place comprend un certain nombre de préparatifs. La première grande étape est la génération des secrets d'authentification, décrite en section II.2. Cette génération s'appuie sur les informations présentes dans les référentiels électoraux, lesquels sont fournis par le MEAE (voir la section II.1).

Cette première étape s'accompagne de la création de fichiers d'import qui sont à intégrer dans le SI VOTE, en plus des référentiels électoraux. Ces fichiers ne contiennent ni les identifiants ni les mots de passe, ni aucune information qui permettrait de les reconstituer.

Enfin, la dernière grande étape de la mise en place est la génération de la clef publique de chiffrement, décrite en section II.3.

Sommaire

II.1 Les référentiels électoraux 21
II.1.1 Les fichiers principaux 21
II.1.2 Autres fichiers techniques 23
II.2 La génération des secrets d'authentification 24
II.2.1 Détails des flux et chronologie 24
II.2.2 Génération de EL_CODE_CC_LOGIN par le SI CODE 25
II.2.3 Génération des identifiants et des mots de passe 26
II.2.4 Fusion et import des authentifications 28
II.3 La génération de la clef de chiffrement des suffrages 29
II.3.1 Les principes 29
II.3.2 La mise en oeuvre 29

II.1 Les référentiels électoraux

II.1.1 Les fichiers principaux

Les référentiels fournis par le MEAE sont composés des fichiers suivants. Ils sont importés dans le SI CODE qui les reformate en vu d'un import dans le SI VOTE.

LCC. Ce fichier effectue l'inventaire des circonscriptions et des postes consulaires (le niveau de découpage le plus fin).

Il contient les colonnes suivantes :

- CODE_LEC, l'identifiant du poste,
- LIBELLE_LEC, le libellé du poste,
- CODE_CIRC_ELEC, l'identifiant de la circonscription du poste,
- LIBELLE_CIRC_ELEC, le libellé de la circonscription,
- TYPE_SCRUTIN, un code définissant la modalité de vote. Pour les élections consulaires, elle peut valoir "LISTE" ou "UNINOMINAL" selon la taille de la circonscription, mais elle vaut toujours "LISTE" pour les élections législatives,
- LEC_NUM, le numéro de la LEC.

RFELEC. Ce fichier répertorie les électeurs.

Il contient les colonnes suivantes :

- NUMIC, un identifiant unique attribué par le MEAE, connu de l'électeur,
- CIVILITE, la civilité du citoyen (M ou Mme),
- NOM, le nom d'usage de l'électeur,
- PRENOM, le prénom d'usage de l'électeur,
- NUM_SMS, le numéro de téléphone de l'électeur, au format international,
- MAIL, l'adresse mail de l'électeur,
- CODE_LEC, l'identifiant du poste de l'électeur,
- PRENOMS_CIVIL, les prénoms de l'électeur dans l'état civil, séparés par des espaces,
- NOM_NAISSANCE, le nom de l'électeur dans l'état civil,
- SEXE, le sexe de l'électeur (F ou M),
- DATE_NAISSANCE, la date de naissance de l'électeur, au format jj/mm/aaaa.

LCA. Ce fichier liste les candidatures.

Il contient les colonnes suivantes :

- TITRE_LISTE, le titre de la liste de candidats,
- CODE_CANDIDATURE, le numéro de dépôt de la candidature,
- NOM_CANDIDAT, le nom du candidat,
- PRENOM_CANDIDAT, le prénom du candidat,
- NOM_SUPPLEANT, le nom du suppléant,
- PRENOM_SUPPLEANT, le prénom du suppléant,
- ORDRE_CANDIDATURE, l'ordre d'affichage de la candidature,
- POSITION, l'ordre d'affichage du candidat au sein de la liste,
- MENTION, un texte complémentaire,
- CODE_CIRC_ELEC, l'identifiant de la circonscription électorale associée à la candidature.

II.1.2 Autres fichiers techniques

En plus des fichiers mentionnés dans la section précédente, d'autres fichiers purement techniques sont également nécessaires à l'initialisation du SI CODE, du SI VOTE et du SI RESULTAT.

EN. Le fichier EN, construit à la main sur la base des besoins du MEAE, liste les élections (il y a 11 élections dans le cas des législatives et 130 dans le cas des consulaires). Il contient les colonnes suivantes :

- operationId,
- ordre,
- nom,
- etablissement,
- tourelectionsId,
- typeTitSup,
- nbSiegePourvoir,
- regroupement,
- regleGestion,
- BureauVote.

LC. Le fichier LC, construit à la main sur la base des besoins du MEAE, réunit les listes de candidatures, dérivées du fichier LCA. Il contient les colonnes suivantes :

- FK_OP_id,
- FK_EN_id,
- LC_id,
- LC_ReprésentationSyndicale,
- LC_Affiliation,
- LC_ProfessionFoiFicNom,
- LC_Logo,
- LC_id_reference_liste.

CA. Le fichier CA liste les candidats. Il est généré par le SI CODE à partir du fichier LCA, et doit être importé dans le SI VOTE. Il contient les colonnes suivantes :

- operationId,
- election,
- listeCandidat,
- ordre,
- nom,

- prenom,
- dateNaissance (non utilisé pour le MEAE),
- matricule (non utilisé pour le MEAE),
- profession_de_foi,
- info1 (nom des autres candidats pour un scrutin de liste ; vide pour un scrutin uninominal),
- info2,
- info3,
- info4,
- info5,
- CA_Tit_FK_EN_Id.

II.2 La génération des secrets d'authentification

Les secrets d'authentification sont les identifiants et les mots de passe. Ils servent au moment de l'authentification des électeurs et sont nécessaires pour soumettre des bulletins légitimes. Cette légitimité repose sur l'hypothèse que seuls les électeurs éligibles sont en possession d'à la fois un identifiant et un mot de passe. Pour que cette hypothèse soit vérifiée, ces secrets sont générés sur deux machines séparées, le SI CODE et le SI CODE_{B}. Ces dernières génèrent les secrets sous une forme chiffrée, ce qui protège leur confidentialité. Les secrets sont envoyés aux électeurs via deux canaux séparés : les identifiants sont envoyés par courriel tandis que les mots de passe sont envoyés par SMS. Pour cela, nous faisons appel à des prestataires d'envoi de courriel et de SMS, qui ont pour responsabilité de déchiffrer les secrets et de veiller à leur bonne délivrance.

II.2.1 Détails des flux et chronologie

Afin de faciliter la compréhension du protocole, nous donnons la figure II.1 qui résume les informations échangées entre les différents acteurs (dans la colonne de gauche, les couleurs des encadrés en gras indiquent les éléments gérés par un même acteur). Pour commencer, les prestataires d'envoi de courriel et de SMS génèrent chacun une paire de clefs RSA à l'aide d'un outil que nous leur fournissons. Ils communiquent chacun leur clef publique, qui est utilisée lors du de chiffrement des secrets d'authentification.

Après l'initialisation des machines, le référentiel électeur (le fichier RFELEC) est chargé dans le SI CODE qui en extrait un fichier EL_CODE_CC_LOGIN. Ce fichier ne prend en compte que les électeurs ayant renseigné une adresse courriel et un numéro de téléphone, et est utilisé par les SI CODE et SI CODE_{B} pour générer les identifiants et les mots de passe. En plus des secrets d'authentification à proprement parler, le SI CODE et le SI CODE_{B} génèrent les fichiers AUT_CA et AUT_CB. Ces deux fichiers sont communiqués au tiers vérificateur. Ils sont ensuite fusionnés par le SI CODE en un seul fichier AUT_CC, lequel est destiné au SI VOTE.

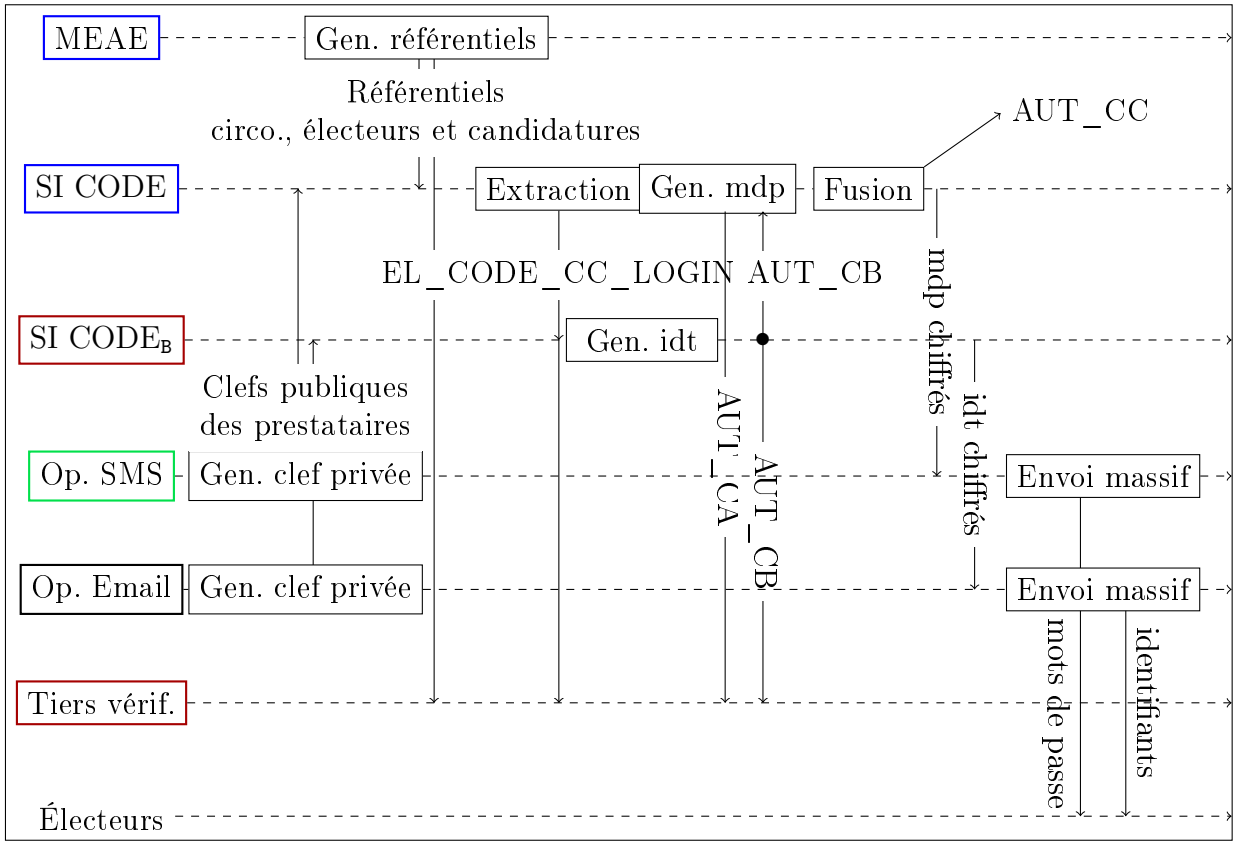


FIGURE II.1 – Schématisation des flux échangés lors de la génération des secrets d'authentification.

À noter que les échanges entre les différents systèmes d'information se font via des supports inaltérables, sous le contrôle du bureau de vote. Cela assure l'authenticité et l'intégrité des échanges. L'intégrité des données le long de leur conservation, elle, est garantie grâce à des prises d'empreintes.

II.2.2 Génération de EL_CODE_CC_LOGIN par le SI CODE

Le référentiel électeur fourni par le MEAE est d'abord importé dans le SI CODE centralisateur qui s'occupe d'extraire les informations exploitées par le SI CODE_{B}, informations regroupées dans le fichier EL_CODE_CC_LOGIN. Ce fichier ne concerne que les électeurs ayant à la fois renseigné un courriel et un numéro de téléphone.

Il contient les colonnes suivantes :

- electeurid, un identifiant technique associé à chaque électeur (le NUMIC) ;
- civilite, la civilité associée à l'électeur ;
- nom, le nom de famille de l'électeur ;
- prenom, les prénoms de l'électeur ;
- mail, l'adresse courriel de l'électeur.

II.2.3 Génération des identifiants et des mots de passe

La génération des identifiants et des mots de passe se fait de manière quasiment symétrique : la seule différence vient du fait que les mots de passe sont envoyés aux électeurs par SMS tandis que les identifiants sont envoyés par courriel, ce qui implique des écarts de traitement minimes liés à la délivrance des SMS. Dans cette section, nous décrivons point par point la génération des identifiants par le SI CODE_{B}, et nous expliquons systématiquement les différences pouvant apparaître lors de la génération des mots de passe par le SI CODE. Dans les deux cas, la génération se fait à partir du fichier EL_CODE_CC_LOGIN.

La génération des identifiants se fait sur le SI CODE_{B}. Pour chaque électeur, le SI CODE_{B} génère un identifiant secret unique et des éléments publics. Les identifiants secrets sont des chaînes de caractères de longueur 15, choisies avec plus de 80 bits d'entropie. Le jeu de caractères retenu possède 49 caractères différents mais facilement reconnaissables par l'œil humain, ce qui permet aux électeurs de les saisir lors de leur authentification. Ces identifiants secrets sont écrits dans un fichier séparé, chiffré et envoyé au prestataire courriel. Ce dernier se charge de le déchiffrer et d'envoyer leurs identifiants aux électeurs. Quant aux éléments publics, il sont écrits en clair dans un fichier AUT_CB, qui sera importé dans la solution de vote et transmis au tiers vérificateur afin qu'il puisse contrôler la légitimité des bulletins.

La génération des mots de passe se fait sur le SI CODE. Pour chaque électeur, le SI CODE génère un mot de passe secret unique et des éléments publics. Les mots de passe sont générés de la même façon que les identifiants secrets. En revanche, ils ne sont pas écrits dans un unique fichier : les électeurs sont regroupés par zone géographique au travers de leur établissement, et il y a un fichier par zone. Chacun de ces fichiers est chiffré et envoyé au prestataire SMS. Ce dernier se charge de déchiffrer les fichiers et d'envoyer leurs identifiants aux électeurs, sachant qu'à chaque fichier est associée une plage horaire d'envoi. Quant aux éléments publics, ils sont écrits en clair dans un fichier AUT_CA, qui sera importé dans la solution de vote et transmis au tiers vérificateur afin qu'il puisse contrôler la légitimité des bulletins.

Choix du niveau d'entropie. Le niveau d'entropie des identifiants et des mots de passe a été choisi afin d'écarter tout risque de bourrage d'urne de la part du SI VOTE. En effet, pour pouvoir créer un bulletin qui semble légitime, le SI VOTE a besoin de signer ce bulletin, ce qui nécessite une clef privée de signature. Pour obtenir une telle clef, il peut soit tenter de calculer un logarithme discret (ce que nous considérons comme impossible étant donné la taille de la clef), soit dériver la clef à partir de l'identifiant et du mot de passe d'un électeur. Or, étant donnée la durée du scrutin, on peut considérer comme impossible le fait de trouver par la force brute ne serait-ce qu'un seul secret de 80 bits.

II.2.3.a Inventaire et contenu des fichiers générés par le SI CODE_{B}

Le SI CODE_{B} génère différents fichiers, qui sont listés ci-dessous.

AUT_CB. Le fichier AUT_CB, à importer dans le SI VOTE et à transférer au tiers vérificateur. Il contient les colonnes suivantes :

- electeurid, lu depuis electeurid dans EL_CODE_CC_LOGIN,
- idB, la valeur de id_{B} générée par SI CODE_{B},

- pkB, la valeur de pk_B générée par SI CODE_B.

LOGIN-chiffre. Le fichier LOGIN-chiffre est un fichier chiffré en AES. Une fois déchiffré, il contient les colonnes suivantes :

- EL_CIVILITE, lu depuis civilite dans EL_CODE_CC_LOGIN,
- EL_NOM, lu depuis nom dans EL_CODE_CC_LOGIN,
- EL_PRENOM, lu depuis prenom dans EL_CODE_CC_LOGIN,
- EL_LOGIN, l'identifiant secret généré par SI CODE_B, noté part_B,
- EL_EMAIL, lu depuis mail dans EL_CODE_CC_LOGIN.

LOGIN-pass. Le fichier LOGIN-pass contient la clef AES qui permet de déchiffrer le fichier LOGIN-chiffre, elle-même chiffrée avec la clef publique du prestataire mail.

II.2.3.b Inventaire et contenu des fichiers générés par SI CODE

Le SI CODE génère différents fichiers, qui sont listés ci-dessous.

AUT_CA. Le fichier AUT_CA, à importer dans le serveur de vote et à transférer au tiers vérificateur. Il contient les colonnes suivantes :

- electeurid, lu depuis electeurid dans EL_CODE_CC_LOGIN,
- idA, la valeur de id_A générée par SI CODE,
- pkA, la valeur de pk_A générée par SI CODE.

PASSWORD-chiffre. Les fichiers PASSWORD-chiffre sont des fichiers chiffrés en AES. Il y en a autant que de groupes géographiques. Une fois déchiffrés, ils contiennent les colonnes suivantes :

- EL_CIVILITE, lu depuis civilite dans EL_CODE_CC_LOGIN,
- EL_NOM, lu depuis nom dans EL_CODE_CC_LOGIN,
- EL_PRENOM, lu depuis prenom dans EL_CODE_CC_LOGIN,
- EL_PASSWORD, le mot de passe secret généré par SI CODE, noté part_A,
- EL_NUM_SMS, lu depuis le RFELEC.

PASSWORD-pass. Les fichiers PASSWORD-pass contiennent chacun une clef AES qui permet de déchiffrer le fichier PASSWORD-chiffre correspondant, elle-même chiffrée avec la clef publique du prestataire SMS.

II.2.3.c Algorithmes de génération des fichiers

Dans cette section, nous présentons les algorithmes de génération des fichiers utilisés par le SI CODE_B. La génération des fichiers par le SI CODE se fait de la même manière, à ceci près que les électeurs sont regroupés par zone géographique. Le SI CODE_B génère les fichiers AUT_CB, LOGIN-chiffre et LOGIN-pass en procédant électeur par électeur. Pour chaque électeur, il effectue les opérations suivantes :

1. L'identifiant secret part_B est généré aléatoirement avec plus de 80 bits d'entropie.
2. À partir de cet identifiant est dérivée une chaîne longue sk_B de 253 bits, qui est interprétée comme un entier. Pour ce faire, nous utilisons la procédure pbkdf2 [MKR17].
3. À partir de cette chaîne longue sk_B est dérivé $\mathsf{pk}_\text{B} = g^{\mathsf{sk}_\text{B}}$, où g est le générateur de la courbe elliptique edwards25519.
4. À partir de la chaîne longue sk_B est dérivé $\mathsf{id}_\text{B} = \text{sha256}(\mathsf{sk}_\text{B}||\mathsf{salt})$, où salt est un sel publique et commun à chaque identifiant et mot de passe, mais spécifique à chaque génération d'identifiants et de mots de passe.
5. La valeur de id_B (resp. pk_B) est utilisée pour remplir le champ correspondant dans AUT_CB.
6. La valeur de part_B est utilisée pour renseigner le champ EL_LOGIN dans LOGIN-chiffre. Elle correspond à l'identifiant de l'électeur.

II.2.3.d Chiffrement des identifiants et mots de passe pour publipostage

Les identifiants et mots de passe sont chiffrés avant d'être transmis aux prestataires mail et SMS. Les identifiants sont regroupés dans un unique fichier à destination du prestataire mail tandis que les mots de passe sont séparés par regroupement géographique des électeurs. Cela permet au prestataire SMS d'envoyer les mots de passe en période ouvrée, ce qui augmente le taux de délivrance en pratique. Chaque fichier est chiffré de manière séparée, ce qui signifie qu'il y a un unique fichier chiffré pour les identifiants et de multiples fichiers chiffrés pour les mots de passe.

Nous fournissons aux prestataires un logiciel qui permet de générer des paires de clefs RSA, ainsi que de déchiffrer des fichiers. Le prestataire utilise le logiciel pour générer sa paire de clefs et transmet sa clef publique. Cette dernière est utilisée pour chiffrer les fichiers.

II.2.4 Fusion et import des authentifications

Après leur génération, les fichiers AUT_CB et AUT_CA sont fusionnés en un seul fichier AUT_CC par le SI CODE. (Tout comme AUT_CB et AUT_CA, AUT_CC ne concerne que les électeurs ayant à la fois renseigné un numéro de téléphone et une adresse courriel.) La jointure s'effectue sur le champ electeurid (qui correspond au numic) et on écrit le fichier AUT_CC qui contient les colonnes

- login, le produit des points pk_A et pk_B ($\mathsf{pk} = \mathsf{pk}_\text{A}\mathsf{pk}_\text{B}$)
- password, $\text{sha256}(\mathsf{sel}||\mathsf{id}_\text{A})$
- sel, 64 bits aléatoires uniques à l'électeur

- sel_b, 64 bits aléatoires uniques à l'électeur
- h_b, sha256($\mathsf{sel_}b||\mathsf{id_B}$)
- $\mathsf{pk_A}$, lu depuis AUT_CA
- $\mathsf{pk_B}$, lu depuis AUT_CB

Une fois le fichier AUT_CC généré, il est importé dans le SI VOTE pour renseigner la table d'authentification.

II.3 La génération de la clef de chiffrement des suffrages

II.3.1 Les principes

Dans notre solution, le choix de l'électeur est chiffré à l'aide d'un algorithme de chiffrement à clef publique, ce qui permet de protéger le secret du vote tout au long du scrutin. La clef de chiffrement est générée dans un environnement sécurisé, puis la clef de déchiffrement est partagée en fragments à l'aide d'un processus de partage de secret à la Shamir [Sha79]. Ce processus permet de distribuer un fragment de clef à différentes personnes de confiance (en l'occurrence, les membres du bureau de vote), de manière à ce qu'un seuil de fragments soit nécessaire à toute opération de déchiffrement. Cela permet au dépouillement de ne pas nécessiter la disponibilité de tout le bureau de vote, sans que chaque membre (ou même une collusion réunissant moins de membres que le seuil nécessaire) n'ait la moindre information sur la clef privée.

Pour des raisons pratiques, les membres du bureau de vote ne repartent pas avec leur fragment de clef mais choisissent à la place une phrase secrète qui est utilisée pour le chiffrer. Chaque phrase secrète est connue uniquement du membre qui l'a saisie et est nécessaire pour utiliser son fragment. Ni la clef de déchiffrement ni les phrases secrètes ne sont enregistrées par la solution de vote. Les fragments, quant à eux, sont enregistrés sous forme chiffrée sur un support physique conservé dans un coffre-fort. (Ils ne sont donc pas enregistrés en clair.)

II.3.2 La mise en oeuvre

Pour donner plus de détails, nous notons q le nombre premier défini dans l'équation (1), $\mathbb{F}_q$ le corps à q éléments, m le nombre de membres du bureau de vote et t le nombre de fragments nécessaires pour recouvrer la clef privée. Notre algorithme de génération de clef commence par tirer aléatoirement $a_0, \cdots, a_{t-1}$, des éléments de $\mathbb{F}_q$ qui définissent un polynôme $f = \sum_{i=0}^{t-1} a_i X^i$. La clef privée $\mathsf{sk_{dec}}$ est alors définie par $\mathsf{sk_{dec}} = f(0)$, et la clef publique de chiffrement $\mathsf{pk_{enc}}$ est définie par $\mathsf{pk_{enc}} = g^{\mathsf{sk_{dec}}}$. Pour chaque membre, numéroté de 1 à m, le fragment secret est $s_i = f(i)$ (où i est le numéro du membre) et la clef publique associée est $\mathsf{pk_i} = g^{s_i}$.

La génération des clefs est faite sur le SI RESULTAT et produit les fichiers suivants.

CLE_PUBLIQUE_BUREAU_VOTE. Ce fichier contient la clef publique de chiffrement des suffrages, propre au bureau de vote. Il doit être importé sur le SI VOTE.

Clé_Président. Ce fichier contient la clef publique propre au président.

Clé_Assesseur[i]. Ce fichier contient la clef publique propre au membre du bureau de vote numéro i. Il y autant de fichiers que de membres.

Chapitre III

La phase de vote

Sommaire

III.1 Les demandes de renouvellement 31
III.1.1 Authentification d'une demande de renouvellement 32
III.1.2 Résolution d'une demande de renouvellement 33
III.2 L'authentification des électeurs 34
III.2.1 Authentification par identifiant et mot de passe 34
III.2.2 Authentification par France Identité Numérique 35
III.2.3 Partage d'une clef publique anonymisée 37
III.3 Création d'un bulletin chiffré, valide et légitime 37
III.3.1 Chiffrement du choix de l'électeur et preuves de validité 37
III.3.2 Signature du bulletin par le client de vote 39
III.3.3 Validation du vote 39
III.3.4 Enregistrement de la transaction de vote 39
III.3.5 Émission d'un cachet serveur 40
III.3.6 Confirmation du vote 40
III.4 La vérification individuelle 40
III.4.1 Vérification automatique par le navigateur 40
III.4.2 L'accusé de réception et le cachet serveur 40

III.1 Les demandes de renouvellement

Dans le cas où un électeur n'aurait pas reçu (ou aurait perdu) son identifiant ou son mot de passe, nous proposons un service qui permet aux électeurs d'effectuer une demande de renouvellement d'un de ses deux secrets. La demande de renouvellement de l'identifiant nécessite de connaître son mot de passe et d'avoir accès à sa boîte mail. Le nouvel identifiant est affiché à l'écran. En revanche, la demande de renouvellement du mot de passe demande de connaître son identifiant et d'avoir accès à sa boîte mail ; le nouveau mot de passe est envoyé sur le numéro de l'électeur, par SMS ou par la messagerie instantanée Signal (au choix de l'électeur). Lors d'une demande de renouvellement, le mot de passe (ou l'identifiant) saisi par

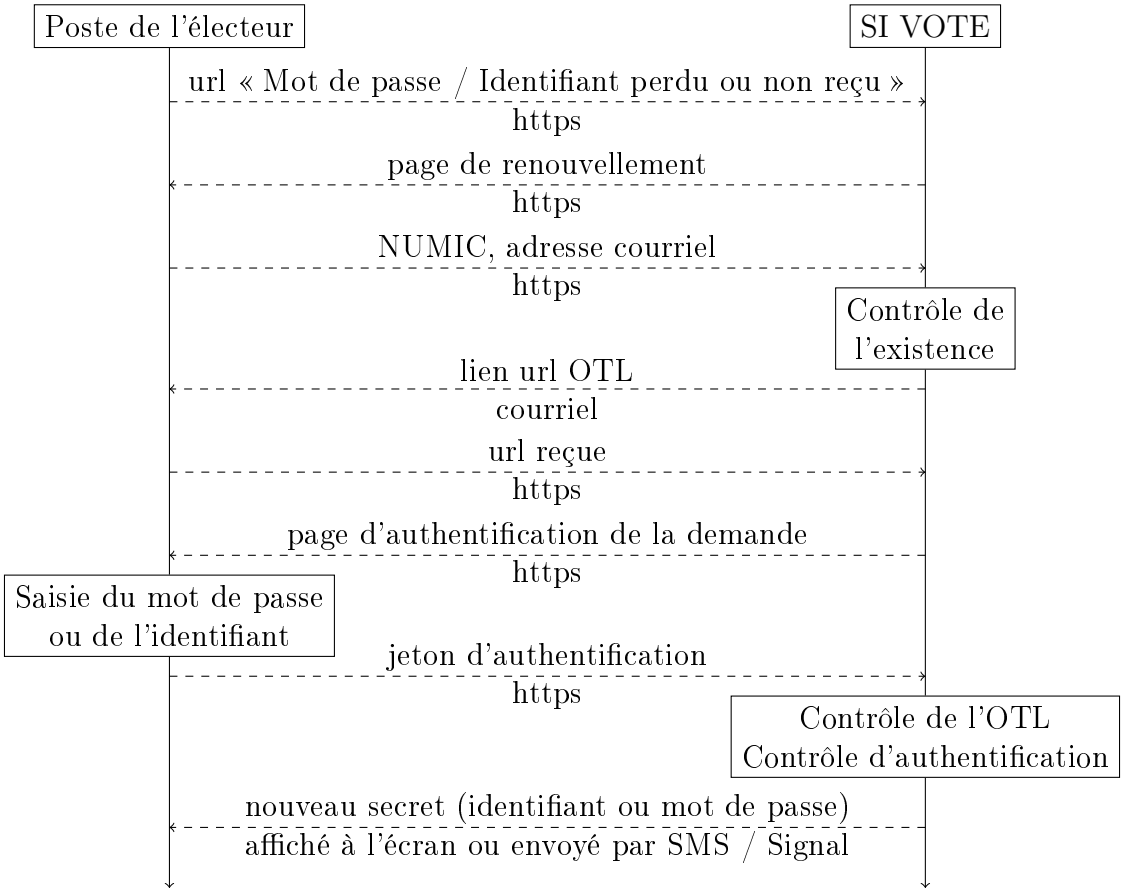


FIGURE III.1 – Échanges effectués lors d'une demande de renouvellement.

l'utilisateur n'est pas transmis tel quel au serveur : pour plus de sécurité, nous utilisons un mécanisme de dérivation côté navigateur, de manière à ce que le serveur n'ait connaissance que du secret renouvelé et pas du secret saisi.

Pour illustrer le fonctionnement des demandes de renouvellement, nous donnons la figure III.1.

III.1.1 Authentification d'une demande de renouvellement

En dehors des différences mentionnées ci-dessus, le renouvellement de l'identifiant et du mot de passe fonctionnent exactement de la même manière. Pour plus de clarté, nous explicitons le fonctionnement dans les deux cas.

III.1.1.a Demande de renouvellement de l'identifiant

Lors d'un renouvellement de l'identifiant, l'utilisateur doit d'abord saisir son numic et son adresse courriel. Les valeurs saisies sont contrôlées côté serveur, lequel déclenche l'envoi d'un courriel sur l'adresse de l'électeur. Ce courriel contient un lien vers le formulaire de demande de renouvellement d'identifiant, lien qui contient un code à usage unique qui est associé à l'électeur par le SI VOTE et est contrôlé lors de la soumission du formulaire. Pour remplir le

formulaire, l'utilisateur saisit son mot de passe part_A, qui est utilisé pour calculer id_A et pk_A comme expliqué dans la section II.2.3.c. Le client de vote envoie un jeton d'authentification, qui contient id_A et pk_A. La valeur de pk_A sert d'indexe pour retrouver la ligne correspondante dans la table d'authentification, si elle existe. Les colonnes password et sel sont alors utilisées : le serveur vérifie que $\mathsf{password} = \text{sha256}(\mathsf{sel}||\mathsf{id}_A)$ (comme dans la section II.2.4).

III.1.1.b Demande de renouvellement du mot de passe

Lors d'un renouvellement du mot de passe, l'utilisateur doit d'abord saisir son numic et son adresse courriel. Les valeurs saisies sont contrôlées côté serveur, lequel déclenche l'envoi d'un courriel sur l'adresse de l'électeur. Ce courriel contient un lien vers le formulaire de demande de renouvellement de mot de passe, lien qui contient un code à usage unique qui est associé à l'électeur par le SI VOTE et est contrôlé lors de soumission du formulaire. Pour remplir le formulaire, l'utilisateur saisit son identifiant part_B, qui est utilisé pour calculer id_B et pk_B comme expliqué dans la section II.2.3.c. Le client de vote envoie un jeton d'authentification, qui contient id_B et pk_B. La valeur de pk_B sert d'indexe pour retrouver la ligne correspondante dans la table d'authentification, si elle existe. Les colonnes h_b et sel_b sont alors utilisées : le serveur vérifie que $\mathsf{h_b} = \text{sha256}(\mathsf{sel_}b||\mathsf{id}_B)$ (comme dans la section II.2.4).

III.1.2 Résolution d'une demande de renouvellement

Une fois la demande authentifiée, le serveur génère un nouveau secret (identifiant ou mot de passe), met à jour la table d'authentification et transmet le nouveau secret à l'électeur. Dans ce qui suit, nous expliquons comment est mise à jour la table d'authentification suite à une demande de renouvellement.

III.1.2.a En cas de renouvellement de l'identifiant

Dans le cas d'un renouvellement d'identifiant, le serveur génère un nouvel identifiant aléatoire part_B qui sera affiché (en fin de parcours) sur l'écran de l'électeur. Ce nouvel identifiant est utilisé pour dériver de nouvelles valeurs de id_B, sk_B et pk_B (voir la section II.2.3.c). Le serveur génère également un nouveau sel aléatoire $\mathsf{sel_}b$ et met à jour les colonnes suivantes :

- La colonne login prend la valeur du produit $\mathsf{pk}_A\mathsf{pk}_B$, en prenant en compte la nouvelle valeur de pk_B ;
- La colonne sel_b prend la nouvelle valeur de $\mathsf{sel_}b$;
- La colonne h_b prend la nouvelle valeur de $\text{sha256}(\mathsf{sel_}b||\mathsf{id}_B)$;
- La colonne pk_b prend la nouvelle valeur de pk_B ;
- La colonne emetteur_pk prend la valeur A ;
- La colonne preuve_legitimite prend pour valeur une signature (voir la section I.6.4) du message $m = \mathsf{pk}_A$ (la clef publique inchangée) faite avec la clef de signature sk_B (la clef privée associée à la clef publique modifiée). Cette signature sert de preuve de connaissance de sk_B et atteste que les modifications de la table font suite à une demande de renouvellement. (Comme $\mathsf{sk} = \mathsf{sk}_A + \mathsf{sk}_B$, un attaquant connaissant sk_B ne peut pas connaître sk sans connaître sk_A.)

III.1.2.b En cas de renouvellement du mot de passe

Dans le cas d'un renouvellement de mot de passe, le serveur génère un nouveau mot de passe aléatoire part_A qui sera envoyé par SMS ou par Signal (en fin de parcours). Ce nouveau mot de passe est utilisé pour dériver de nouvelles valeurs de id_A, sk_A et pk_A (voir la section II.2.3.c). Le serveur génère également un nouveau sel aléatoire sel et met à jour les colonnes suivantes :

- La colonne login prend la valeur du produit $\mathsf{pk}_A\mathsf{pk}_B$, en prenant en compte la nouvelle valeur de pk_A ;
- La colonne sel prend la nouvelle valeur de sel ;
- La colonne password prend la nouvelle valeur de $\text{sha256}(\mathsf{sel}||\mathsf{id}_A)$;
- La colonne pk_a prend la nouvelle valeur de pk_A ;
- La colonne emetteur_pk prend la valeur B ;
- La colonne preuve_legitimite prend pour valeur une signature (voir la section I.6.4) du message $m = \mathsf{pk}_B$ (la clef publique inchangée) faite avec la clef de signature sk_A (la clef privée associée à la clef publique modifiée). Cette signature sert de preuve de connaissance de sk_A et atteste que les modifications de la table font suite à une demande de renouvellement. (Comme $\mathsf{sk} = \mathsf{sk}_A + \mathsf{sk}_B$, un attaquant connaissant sk_A ne peut pas connaître sk sans connaître sk_B.)

III.2 L'authentification des électeurs

L'authentification des électeurs se fait soit par identifiant et mot de passe, soit par France Identité Numérique. Dans les deux cas, le parcours d'authentification permet au client de vote de générer une clef privée de signature, laquelle lui permettra de signer le bulletin de vote de l'électeur et donc de garantir sa légitimité (voir les sections III.2.1 et III.2.2). Cette clef est uniquement connue du client de vote et peut être utilisée sans rattacher le bulletin à l'identité de l'électeur, car nous utilisons un processus d'anonymisation basé sur un partage de clef à la Diffie-Hellman.

III.2.1 Authentification par identifiant et mot de passe

Lorsque l'électeur s'authentifie par identifiant et mot de passe, le client de vote s'occupe de dériver un secret long sk_A à partir de son mot de passe et un autre secret sk_B à partir de l'identifiant. Ces deux secrets sont combinés en un seul secret sk qui est utilisé pour déterminer une clef publique pk. Le client de vote transmet alors pk au serveur, ainsi que des hachés de sk_A et sk_B (qui servent à des fins d'authentification). Ainsi, ni les secrets d'authentification, ni sk_A, ni sk_B, ni sk n'est transmis au serveur. Remonter à l'une de ces informations à partir des éléments transmis est cryptographiquement impossible (on ne peut pas trouver un secret long à partir de son haché, ni retrouver une clef privée à partir d'une clef publique).

Nous donnons la figure III.2, qui schématise les deux chaînes de dérivation suivies ; dans cette figure, nous notons part_A (resp. part_B) le mot de passe (resp. l'identifiant) de l'électeur,

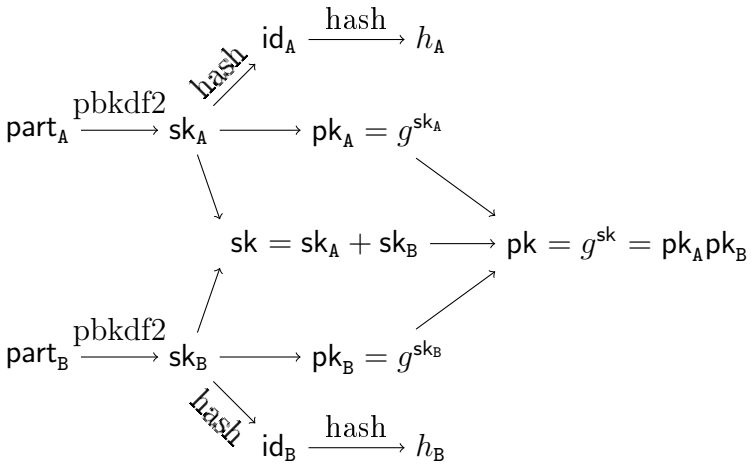


FIGURE III.2 – Schéma de dérivation pour l'authentification avec identifiant et mot de passe.

sk sa clef de signature et pk la clef publique associée. Pour dériver un secret long à partir d'un identifiant ou d'un mot de passe, nous utilisons la même technique que dans la section II.2.3.c. Les secrets $\mathsf{sk_A}$ et $\mathsf{sk_B}$ sont ensuite additionnés pour former sk, et on calcule $\mathsf{pk} = g^{\mathsf{sk}}$, où g est le générateur de la courbe elliptique défini dans la RFC [JL17]. Le client de vote envoie au serveur l'information $\mathsf{pk}||\mathsf{id_A}||\mathsf{id_B}$. Pour contrôler l'authentification, le serveur retrouve d'abord la ligne correspondante à l'aide de pk puis vérifie que h_A et h_B correspondent bien à $\mathsf{id_A}$ et $\mathsf{id_B}$. Comme $\mathsf{sk_A}$ fait 253 bits de long, il n'est pas possible de retrouver $\mathsf{sk_A}$ à partir de $\mathsf{id_A}$, c'est pourquoi $\mathsf{id_A}$ est défini comme un simple haché de $\mathsf{sk_A}$ et n'est pas calculé par un pbkdf2. De même, il n'est pas possible de retrouver $\mathsf{id_A}$ à partir de h_A car $\mathsf{id_A}$ fait 256 bits de long. Ainsi, le contrôle de l'authentification côté serveur ne nécessite le calcul d'aucun pbkdf2, ce qui accélère le processus.

III.2.2 Authentification par France Identité Numérique

III.2.2.a Principe

Lorsque l'électeur s'authentifie via France Identité Numérique (FIN), le client de vote s'occupe de générer une paire de clefs $(\mathsf{sk}, \mathsf{pk})$, et envoie la clef publique pk au serveur en même temps que sa requête d'authentification. Le serveur intègre la valeur de pk dans un nonce qui est utilisé dans le protocole d'authentification OpenId Connect [ope23], ce qui lui permet *in fine* de récupérer un jeton signé contenant pk. (Voir la figure III.3, qui schématise ces différents échanges.) La signature de ce jeton est une garantie émise par FIN que le jeton (et donc la valeur de pk) a été généré lors du protocole d'authentification de l'électeur, ce qui permet de faire le lien avec son identité. (Le protocole d'authentification à proprement parler, qui implique des échanges entre FIN et le poste de l'électeur, n'est pas décrit dans ce document et est entièrement sous la responsabilité de FIN.) Comme l'authentification avec FIN est initiée par le client de vote, et que celui-ci vérifie que pk est bien intégré au nonce, le serveur n'a pas de contrôle sur la valeur de pk et le client de vote reste le seul à connaître la clef privée associée. Une idée similaire a été proposée dans [CDGH24], qui utilise également le nonce d'OpenId Connect afin d'obtenir des preuves d'éligibilité transférables.

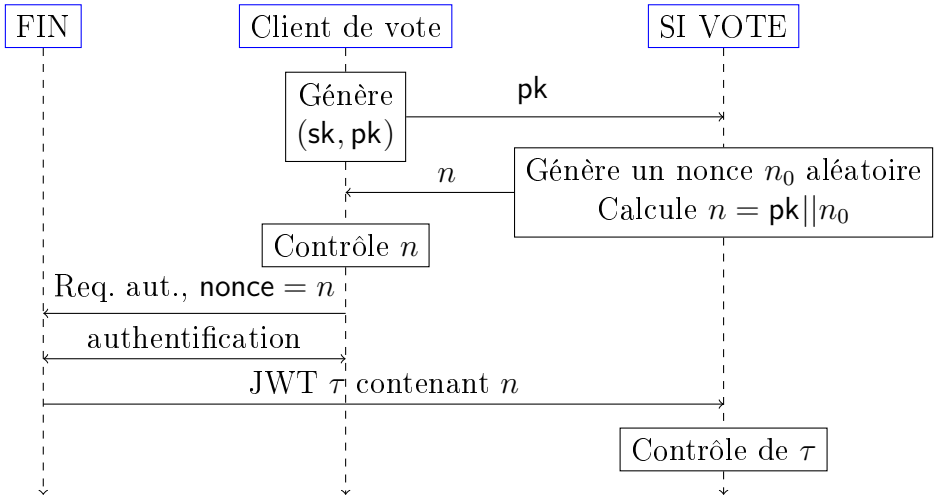


FIGURE III.3 – Schéma des échanges effectués lors de l'authentification par FIN.

III.2.2.b Réconciliation

Un point particulier de l'authentification par FIN est qu'elle fait intervenir deux référentiels différents : le référentiel connu par FIN, en cohérence avec les informations portées par les cartes d'identité numérique d'une part et, d'autre part, le référentiel électeur (RFELEC) tel que fourni par le MEAE. Ces deux référentiels peuvent être en contradiction sur certains éléments, que ce soit du fait d'une erreur humaine lors de la saisie, d'une différence d'encodage des caractères spéciaux ou d'une modification de l'un n'ayant pas été répercutée sur l'autre. Pour cette raison, lorsque l'authentification FIN a réussi, il n'est pas encore possible de déterminer l'électeur authentifié. (En fait, la personne authentifiée pourrait ne pas être inscrite sur la liste électorale.) Il faut donc effectuer une **réconciliation** afin de retrouver l'électeur dans la base de données, ce à partir des informations fournies et certifiées par FIN. Notre algorithme de réconciliation a été fourni par le MEAE et se base sur les spécifications de la plateforme « Interroger sa situation électorale », qui a notamment servi pour effectuer des demandes de procuration lors des élections législatives de 2024. Nous décrivons son fonctionnement dans le paragraphe qui suit.

Étape 1 - Récupération des données. Pour commencer, les données de réconciliation sont récupérées à partir de l'ID TOKEN envoyé par FIN. Pour cela, les champs suivants sont utilisés (en plus du champ *nonce*, qui est utilisé à un autre moment) :

- *birthdate*, la date de naissance au format aaaa-mm-jj ;
- *family_ name*, le nom de naissance ;
- *given_ name*, le(s) prénom(s) dans l'état civil (séparés par des espaces)
- *gender*, le sexe.

Étape 2 - Normalisation. Pour commencer, nous effectuons une normalisation des prénoms dans l'état civil et du nom de naissance.

Étape 3 - Recherche. Une fois les données normalisées, le SI VOTE effectue une recherche exacte dans son référentiel, en se basant sur le sexe, la date de naissance et les noms et prénoms normalisés. S'il y a plusieurs prénoms, il doit y avoir une correspondance exacte sur chaque prénom, et ces derniers doivent apparaître dans le même ordre. Si la recherche renvoie zéro ou plusieurs résultats, la réconciliation échoue et l'électeur n'est pas authentifié par notre solution. Si au contraire la recherche renvoie un unique résultat, ce dernier est utilisé pour déterminer l'électeur authentifié.

III.2.3 Partage d'une clef publique anonymisée

Une fois l'électeur authentifié, le client de vote est en possession d'une paire de clefs $(\mathsf{sk}, \mathsf{pk})$ et le serveur a pris connaissance de la clef publique pk. Le serveur transmet sa clef publique $\mathsf{pk}_{\texttt{anonymisation}}$ qui sera utilisée par le client de vote pour calculer sa clef publique anonymisée $\mathsf{pk}_{\texttt{anonyme}}$ selon le principe de l'échange de Diffie-Hellman :

$$\mathsf{pk}_{\texttt{anonyme}} = \mathsf{pk}_{\texttt{anonymisation}}{}^{\mathsf{sk}}.$$

Cette clef anonymisée est attachée au bulletin de l'électeur et sert à contrôler sa légitimité.

III.3 Création d'un bulletin chiffré, valide et légitime

Une fois le choix de l'électeur confirmé, ce dernier est chiffré à l'aide de la clef publique de chiffrement $\mathsf{pk}_{\texttt{enc}}$ (voir la section II.3 pour la génération de cette clef et la section I.6.3 pour le chiffrement ElGamal). Ce chiffrement s'accompagne de preuves à divulgation nulle de connaissance (PDN), qui garantissent la validité du choix effectué par l'électeur. Par bulletin, nous parlons donc de l'objet qui regroupe à la fois le choix chiffré et ses PDN.

Afin d'illustrer les différents échanges effectués lors de la soumission d'un bulletin, nous donnons la figure III.4 qui résume certaines étapes décrites dans ce chapitre.

III.3.1 Chiffrement du choix de l'électeur et preuves de validité

Le chiffrement du choix et la génération des preuves à divulgation nulle de connaissance (PDN) se fait sur le modèle du protocole Belenios [CGG19] : si on note $n+1$ le nombre de choix possibles pour l'électeur (en comptant le vote blanc), un bulletin est constitué de $n+1$ chiffrés ElGamal (voir la section I.6.3) et d'une preuve de la validité. Ces chiffrés correspondent chacun à un choix spécifique, et le clair associé (1 ou 0) indique si le choix a été retenu ou non. Quant à la preuve, elle vise à garantir que un et un seul de ces chiffrés est un chiffré de 1 tandis que les autres sont des chiffrés de 0, autrement dit qu'une seule option de vote (en incluant le vote blanc) a été sélectionnée.

Pour former une telle preuve, on associe à chaque chiffré une PDN *individuelle* qu'il s'agit d'un chiffré de 0 ou 1 (disjonction de deux preuves de Chaum-Pedersen [CDS94]). Afin de prouver la cohérence globale du bulletin, c'est-à-dire qu'un et un seul choix a été retenu, on donne deux PDN supplémentaires, la preuve *blanche* et la preuve *globale*. En conjonction avec les autres preuves, la preuve blanche prouve que si le vote blanc est retenu, alors aucun autre choix n'est retenu et la preuve globale prouve que si le vote blanc n'est pas retenu,

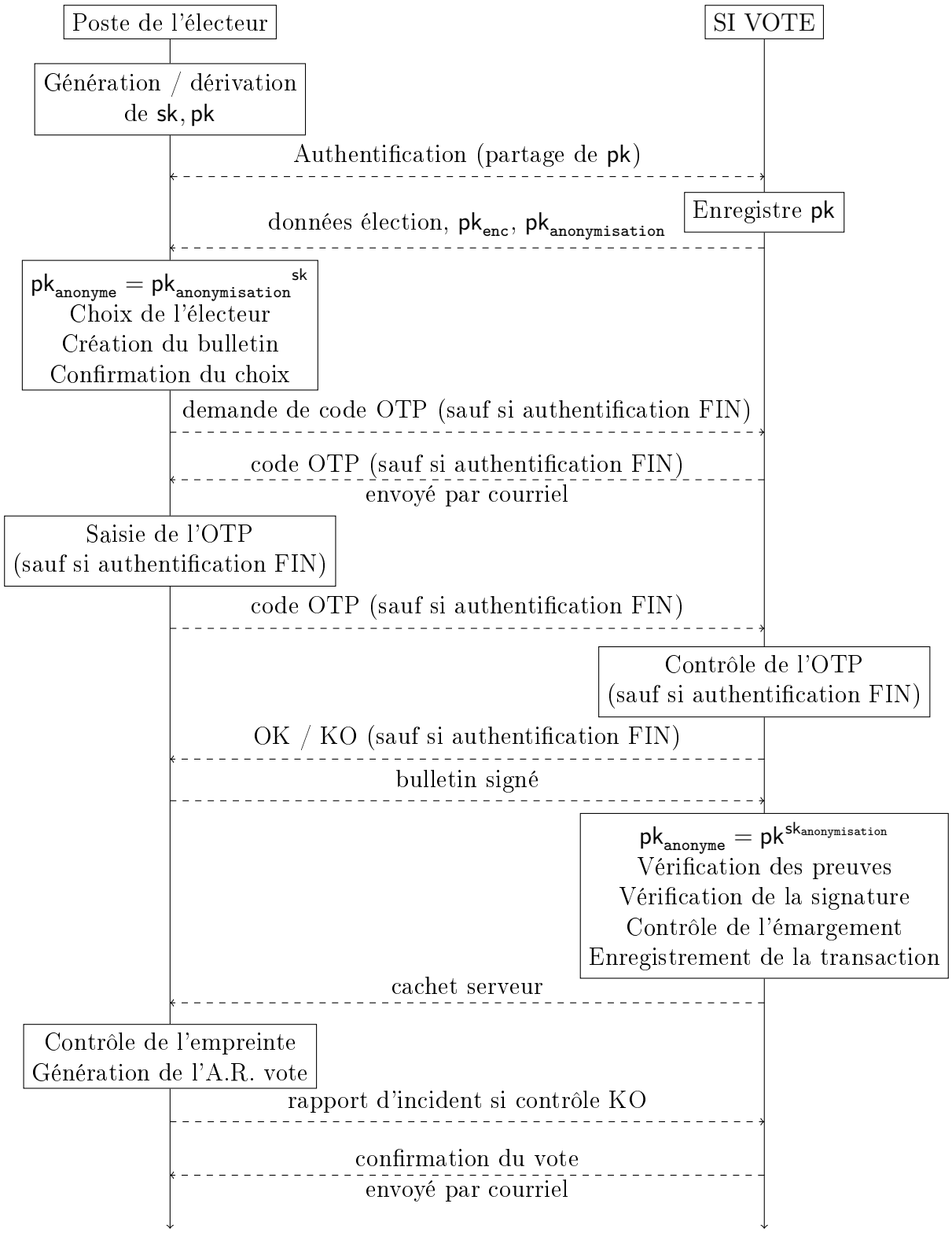


FIGURE III.4 – Schématisation des échanges effectués lors du vote

alors exactement un autre choix est retenu. Ces deux preuves s'appuient sur celles utilisées dans Belenios [CGG19].

III.3.2 Signature du bulletin par le client de vote

Une fois le choix chiffré et les preuves générées, le client de vote utilise sa clef privée sk, la clef publique $\mathsf{pk}_{\texttt{anonymisation}}$ du serveur et sa propre clef publique anonymisée $\mathsf{pk}_{\texttt{anonyme}}$ (voir la section III.2) pour créer une signature du bulletin. Nous utilisons pour cela une version généralisée de la signature de Schnorr où, au lieu de prouver la connaissance d'un secret sk tel que $g = \mathsf{pk}^{\mathsf{sk}}$ avec g fixé, on utilise $g = \mathsf{pk}_{\texttt{anonymisation}}$ et $\mathsf{pk} = \mathsf{pk}_{\texttt{anonyme}}$.

III.3.3 Validation du vote

Après que l'électeur a effectué son choix, il lui est demandé de le confirmer dans une étape de récapitulatif. Cette étape est différente selon que l'électeur s'est authentifié par identifiant et mot de passe ou via FIN. En effet, un électeur s'étant identifié par identifiant et mot de passe doit saisir un code à usage unique (ou OTP, pour *one time password*) qui lui est envoyé par courriel. Ce code est contrôlé côté serveur et est nécessaire à l'enregistrement du vote. Si l'électeur s'est authentifié par FIN, en revanche, cette saisie n'est pas nécessaire et le code OTP n'est pas envoyé. (Cette différence de parcours a été introduite à la demande du ministère.)

III.3.4 Enregistrement de la transaction de vote

Lors de la réception du bulletin b et de sa signature, le serveur contrôle d'abord les preuves de validité du bulletin puis calcule la clef anonymisée $\mathsf{pk}_{\texttt{anonyme}} = \mathsf{pk}^{\mathsf{sk}_{\texttt{anonymisation}}}$, où pk est la clef publique générée lors de l'authentification de l'électeur (voir la section III.2) et où $\mathsf{sk}_{\texttt{anonymisation}}$ est la clef privée associée à $\mathsf{pk}_{\texttt{anonymisation}}$. Il peut alors vérifier la signature du bulletin.

Si le bulletin et sa signature sont valides, le serveur de vote effectue un contrôle de l'émargement puis le bulletin, la clef de vérification $\mathsf{pk}_{\texttt{anonyme}}$ et la signature sont enregistrés dans une même ligne de la table suffrage, en utilisant trois colonnes dédiées. Cette ligne porte également comme information l'élection et l'établissement (*i.e.* la liste électorale consulaire) auxquels le bulletin est rattaché. En plus de l'ajout d'une ligne dans la table suffrage, une ligne est simultanément rajoutée dans la table d'émargement pour matérialiser l'émargement de l'électeur. Cette ligne contient entre autre les informations $\mathsf{pk}_{\texttt{A}}$ et $\mathsf{pk}_{\texttt{B}}$, lues depuis la table d'authentification. Ces valeurs sont initialisées lors de l'import des authentifications (voir la section II.2.3.c) et peuvent être mises à jour suite à une demande de renouvellement (voir la section III.1). En plus de $\mathsf{pk}_{\texttt{A}}$ et $\mathsf{pk}_{\texttt{B}}$ est également inscrit pk, la clef publique générée lors de l'authentification de l'électeur (voir la section III.2). Quand l'électeur s'authentifie par identifiant et mot de passe, on a $\mathsf{pk} = \mathsf{pk}_{\texttt{A}}\mathsf{pk}_{\texttt{B}}$ mais lorsque l'électeur s'authentifie via France Identité Numérique, cette égalité n'est pas vérifiée.

Enfin, la colonne preuve contient

- rien si l'électeur n'a pas fait de demande de renouvellement,

- une signature de pk_A effectuée avec la clef privée associée à pk_B si l'électeur a fait une demande de renouvellement d'identifiant (voir la section III.1.2.a),
- une signature de pk_B effectuée avec la clef privée associée à pk_A si l'électeur a fait une demande de renouvellement de mot de passe (voir la section III.1.2.b),
- le jeton ID TOKEN signé par France Identité Numérique, si l'électeur s'est authentifié via l'identité numérique (voir la section III.2.2).

Les trois premières possibilités sont exclusives et la dernière l'emporte sur les autres.

III.3.5 Émission d'un cachet serveur

Une fois le bulletin et sa signature contrôlés et la transaction de vote effectuée, le serveur produit une signature de l'empreinte du bulletin et l'envoie au client de vote. L'électeur peut alors demander au client de vote de générer un PDF qui matérialise l'accusé de réception de son bulletin. Ce PDF contient un cachet serveur ainsi qu'un lien url vers le site de vérification individuel hébergé par le tiers vérificateur (voir la section III.4). En suivant ce lien, l'électeur peut contrôler la présence de son bulletin dans l'urne ainsi que la validité de son cachet. Nous précisons que, contrairement à la signature émise par le client de vote et servant à la vérification de la légitimité du bulletin, la signature émise par le serveur n'est pas stockée en base de données.

III.3.6 Confirmation du vote

Quelques minutes après la finalisation de la transaction, un courriel est envoyé à l'électeur pour lui confirmer sa participation à l'élection. L'envoi est fait sur l'adresse connue par le système dans le cas d'une authentification par identifiant et mot de passe, et sur l'adresse renseignée par FIN dans le cas d'une authentification par FIN.

III.4 La vérification individuelle

La vérification individuelle est à faire par chaque électeur et consiste à vérifier que son bulletin a bien été inséré dans l'urne. On dit alors que le bulletin a été enregistré *tel quel*.

III.4.1 Vérification automatique par le navigateur

Une première étape de la vérification de l'enregistrement *tel quel* consiste à effectuer des contrôles automatiques côté navigateur. En particulier, le client de vote vérifie que le cachet serveur contient bien l'empreinte du bulletin envoyé. En cas d'écart, l'électeur est alerté et le serveur de vote est notifié.

III.4.2 L'accusé de réception et le cachet serveur

En plus des vérifications automatiques, nous permettons à l'électeur d'enregistrer sur son poste un accusé de réception de son vote. Ce PDF, généré par le navigateur de l'électeur, lui sert de preuve de dépôt de son bulletin dans l'urne et ne peut aucunement être utilisé pour

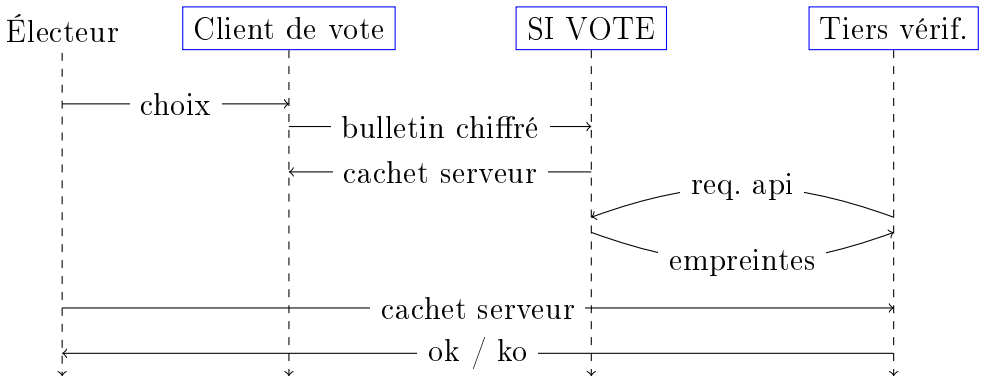


FIGURE III.5 – Schématisation des échanges effectués pour la vérification individuelle.

déterminer son choix. L'accusé de réception contient un cachet serveur (voir la section III.3.5), qui lui-même contient l'empreinte du bulletin ainsi qu'une signature de cette empreinte, émise par le serveur. Le client de vote vérifie automatiquement que l'empreinte contenue dans le cachet est bien celle du bulletin envoyé, mais il ne peut pas contrôler la validité de la signature car il ne connaît pas la clef de vérification associée. Pour effectuer ce contrôle, l'électeur doit suivre un lien présent dans l'accusé de réception, lien qui le mènera sur le site internet du tiers vérificateur (voir la figure III.5). Ce dernier propose un service web permettant à l'électeur de s'assurer de la présence de son bulletin dans l'urne ainsi que de la validité de la signature du serveur. Le contenu du cachet serveur est transporté via l'url du lien, mais l'électeur peut également choisir de le copier-coller depuis son PDF. Le site du tiers vérificateur peut être consulté avec l'url https://www.verifiabilites.lumiglobal.fr. Du fait de l'externalisation de ce service, l'enregistrement *tel quel* est garanti même si le serveur de vote est compromis. En particulier, le tiers vérificateur aura pour responsabilité de s'assurer que l'urne dans laquelle la présence des bulletins a été constatée lors de la vérification individuelle est la même que celle utilisée pour déterminer le résultat de l'élection lors du dépouillement.

Chapitre IV

La phase après clôture

La clôture du vote est un événement qui se déclenche automatiquement à la fin du tour en cours, après un délai de grâce de quelques minutes qui permet aux électeurs déjà authentifiés de terminer leur parcours de vote. Après la date de fin du tour, plus aucune authentification n'est acceptée et après la clôture, plus aucun vote n'est possible. Un certain nombre d'actions sont alors effectuées, notamment pour effectuer des prises d'empreintes, déclencher des exports et lancer l'accumulation des bulletins. Enfin, la phase après clôture comprend le dépouillement, la proclamation des résultats et la génération des preuves associées. La figure IV.1 résume ces différents événements.

Sommaire

IV.1 Export des bulletins et des émargements 42
IV.2 Publication des preuves de légitimité 44
IV.2.1 Légitimité des clefs de vérification liées aux émargements 44
IV.2.2 Légitimité des clefs de vérification liées aux bulletins 46
IV.3 Dépouillement et preuves de déchiffrement 47
IV.3.1 Format des déchiffrements avec preuve 48
IV.3.2 Vérification des preuves de bon déchiffrement 48
IV.3.3 Vérification du résultat de comptage 49

IV.1 Export des bulletins et des émargements

Dans notre solution, les émargements sont nominatifs et horodatés. De plus, chaque émargement porte également des éléments qui permettent de vérifier sa légitimité. Cette vérification est effectuée par le tiers vérificateur, mais pourrait être réalisable par n'importe qui ayant accès aux fichiers de référence nécessaires (en supposant que ceux-ci sont intègres).

En plus de proposer un moyen de vérifier la légitimité des émargements, nous publions également des éléments de preuve (voir la section IV.2) qui prouvent cryptographiquement que chaque bulletin est associé à un émargement, ce sans révéler lequel. En particulier, l'ensemble des vérifications effectuées par le tiers vérificateur permet de s'assurer que chaque bulletin provient d'un électeur légitime et que chaque électeur en a soumis au plus un. Pour

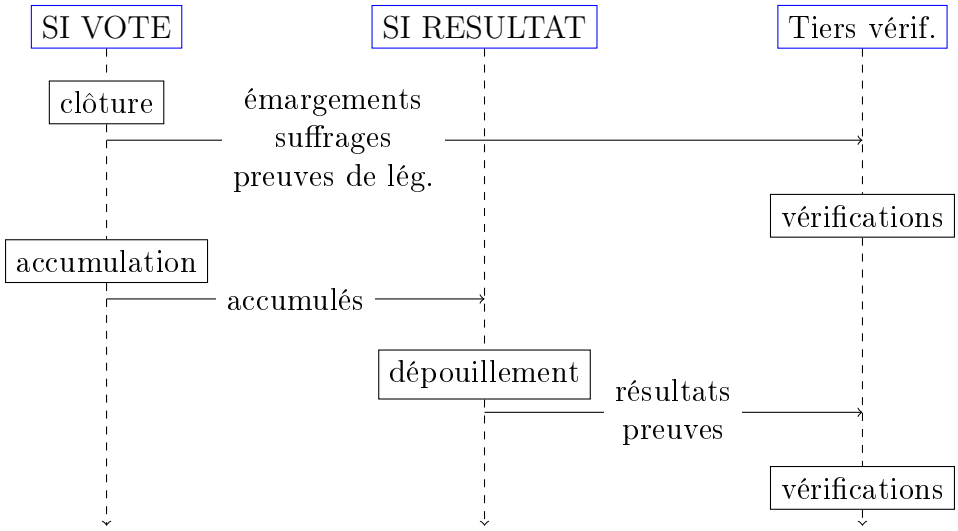


FIGURE IV.1 – Schématisation des différentes opérations survenant après la clôture.

cela, nous attachons aux bulletins des informations supplémentaires, à savoir une signature et sa clef de vérification.

Les émargements. Les émargements sont exportés dans un unique fichier csv qui contient les éléments suivants, séparés par des points-virgules :

- date, qui correspond à l'horodatage des émargements ;
- election_ordre, le numéro de l'élection à laquelle est rattaché l'émargement ;
- electeurid, le numic de l'électeur émargé ;
- pk_a ;
- pk_b ;
- pk ;
- preuve_legitimite, qui est soit *null*, soit une signature de Schnorr, soit un JWT.

Les émargements sont triés par date. La vérification de la légitimité des émargements est détaillée en section IV.2.1.

Les bulletins. Les bulletins sont exportés dans un unique fichier csv, qui contient les éléments suivants, séparés par des points-virgules :

- choix, qui contient le bulletin ;
- infocryptage est un encodage en base 64 de la clef $\mathsf{pk}_{\mathsf{anonyme}}$ (voir section III.3.2) ;
- signaturesuffrage est un encodage en base 64 de la signature du bulletin par le client de vote ;
- electionsuffrage_ordre est le numéro de l'élection à laquelle est rattaché le bulletin ;

- etablissement_ordre est le numéro de la LEC à laquelle est rattaché le bulletin.

Les LEC sont numérotées en commençant par 1001, dans leur ordre d'apparition dans le fichier LCC (voir la section II.1). Les bulletins sont triés par infocryptage ; la vérification de la légitimité des bulletins est détaillée dans la section IV.2.2.

IV.2 Publication des preuves de légitimité

Dans notre solution, les bulletins sont signés et la vérification de ces signatures se fait à l'aide de clefs de vérification qui sont fournies dans la table suffrage. Ainsi, la seule vérification des signatures des bulletins ne suffit pas pour contrôler leur légitimité : il faut également s'assurer de la légitimité des clefs de vérification. Par ailleurs, notre solution fournit des clefs de vérification légitimes dans la table d'émargement ; cependant, afin de ne pas ajouter de lien entre les émargements (nominatifs) et les bulletins, nous utilisons un processus d'anonymisation basé sur un mélange vérifiable. Ainsi, en plus de la table d'émargement et de la table suffrage, nous exportons également une preuve de la légitimité des bulletins dans l'urne, qui garantit qu'à chaque bulletin est associée de manière unique une clef de vérification légitime, ce sans révéler quel électeur a émis quel bulletin. (Nous rappelons que les bulletins sont chiffrés et que la divulgation d'un lien entre un électeur et un bulletin ne constituerait pas une atteinte au secret du vote ; la non divulgation de ce lien n'est donc qu'une couche de sécurité supplémentaire, qui vient s'ajouter au chiffrement.)

IV.2.1 Légitimité des clefs de vérification liées aux émargements

À chaque émargement est associée une clef de vérification pk, mais cette clef peut être différente de la clef générée lors de la génération des secrets d'authentification (dont le processus est décrit en section II.2). Cela vient du fait qu'il peut y avoir des demandes de renouvellement (décrites en section III.1) et que les électeurs peuvent s'authentifier autrement qu'en saisissant leur identifiant et mot de passe (voir la section III.2.2). Ainsi, le tiers vérificateur devra s'assurer que la colonne pk ne contient que des valeurs légitimes. Pour ce faire, il lui faudra se munir du référentiel électeur (le fichier RFELEC, noté $\mathcal{E}$) et des fichiers EL_CODE_CC_LOGIN, AUT_CB et AUT_CA.

Contrôles de cohérence. Tout d'abord, le tiers vérificateur doit vérifier la cohérence du fichier EL_CODE_CC_LOGIN par rapport à RFELEC (le contenu de ce dernier est donné dans la section II.1).

Le numic est utilisé comme matricule et correspond à l'identifiant electeurid, qui intervient dans la section II.2. Quant au code d'établissement, il s'agit d'un sigle qui identifie de manière unique la liste électorale consulaire dans laquelle est inscrit l'électeur. Enfin, les prénoms dans l'état civil, le nom de naissance, le sexe et la date de naissance sont utilisés à des fins de réconciliation (on notera e.infos l'ensemble de ces informations personnelles pour une entrée e).

Le tiers vérifie la cohérence entre EL_CODE_CC_LOGIN et RFELEC, sachant que le premier ne répertorie que les électeurs ayant renseigné une adresse courriel et un numéro de téléphone. Par la suite, le tiers vérifie que l'ensemble des electeurid est le même dans les

trois fichiers EL_CODE_CC_LOGIN, AUT_CB et AUT_CA. Cela lui permet d'ajouter les valeurs $e.\mathsf{pk}_\mathtt{A}$, $e.\mathsf{pk}_\mathtt{B}$ et $e.\mathsf{pk}$ à chaque entrée de son référentiel (quitte à mettre des valeurs nulles lorsque $e.\mathsf{numic}$ n'est pas présent dans EL_CODE_CC_LOGIN). Pour ce faire, le vérifieur lit $e.\mathsf{pk}_\mathtt{A}$ dans AUT_CA et $e.\mathsf{pk}_\mathtt{B}$ dans AUT_CB. Il s'agit de chaînes de caractères en base 64, qui contiennent chacune l'encodage (selon la RFC [JL17]) d'un point de la courbe elliptique. La valeur de $e.\mathsf{pk}$ est calculée en multipliant ces points entre eux. Enfin, le tiers vérifie que tous les $\mathsf{pk}_\mathtt{A}$ (resp. $\mathsf{pk}_\mathtt{B}$) ainsi obtenus sont uniques.

Contrôle des émargements. Une fois les contrôles de cohérence effectués, le vérifieur doit contrôler la légitimité des clefs de vérification présentes dans la liste d'émargement. Pour cela, il pourra utiliser la liste de contrôle donnée ci-dessous.

- Vérifier que les entrées e' de la table d'émargement sont associées à des $\mathsf{electeurid}$ et à des pk deux-à-deux distincts.
- Pour chaque entrée e' de la table d'émargement, vérifier que pk est un encodage en base 64 d'un point de la courbe elliptique (en particulier, que $\mathsf{pk}^q = \mathbb{1}$, où q est défini dans l'équation (1) et où $\mathbb{1}$ est l'élément neutre).
- Pour chaque entrée e' de la table d'émargement, récupérer les valeurs de $\mathsf{electeurid}$, $\mathsf{pk}_\mathtt{A}$, $\mathsf{pk}_\mathtt{B}$, pk et preuve, et chercher une entrée $e \in \mathcal{E}$ telle que $e.\mathsf{numic} = \mathsf{electeurid}$. En l'absence d'une telle entrée, e' est illégitime. Si une telle entrée est trouvée, considérer les cas suivants de manière exclusive (le premier cas correspondant mettant fin au traitement de l'entrée).
  1. Si $\mathsf{pk}_\mathtt{A}\mathsf{pk}_\mathtt{B} \neq \mathsf{pk}$, ce qui inclut le cas où $\mathsf{pk}_\mathtt{A}$ ou $\mathsf{pk}_\mathtt{B}$ ne serait pas donné, e' est légitime si et seulement si toutes les vérifications suivantes aboutissent à des succès.
     — Vérifier que preuve est un JWT valide [JBS15], et vérifier que ce JWT possède une signature valide vis-à-vis d'une des clefs publiques de vérification de France Identité Numérique (FIN). Pour obtenir ces clefs, on pourra utiliser une URL de découverte fournie par FIN.
     — Vérifier que preuve contient comme *claims* un champs *nonce* dont la valeur commence par pk.
     — Contrôler la réconciliation entre les *claims* de l'ID TOKEN et $e.\mathsf{infos}$ (voir la section III.2.2.b).
  2. Si $e.\mathsf{pk} = \mathsf{pk}$, alors e' est légitime.
  3. Si $e.\mathsf{pk}_\mathtt{A} = \mathsf{pk}_\mathtt{A}$, alors e' est légitime si et seulement si preuve est une signature de Schnorr valide (voir section I.6.4) du message $\mathsf{pk}_\mathtt{A}$, faite pour la clef de vérification $\mathsf{pk}_\mathtt{B}$ (comme dans la section III.1.2.a).
  4. Si $e.\mathsf{pk}_\mathtt{B} = \mathsf{pk}_\mathtt{B}$, alors e' est légitime si et seulement si preuve est une signature de Schnorr valide (voir section I.6.4) du message $\mathsf{pk}_\mathtt{B}$, faite pour la clef de vérification $\mathsf{pk}_\mathtt{A}$ (comme dans la section III.1.2.b).
  5. Sinon, e' est illégitime.

IV.2.2 Légitimité des clefs de vérification liées aux bulletins

À chaque bulletin est associé un établissement et une clef de vérification. De même, à chaque émargement est associé un établissement (au travers de la liste électorale consulaire de l'électeur) et une clef de vérification. Cependant, pour éviter de créer un lien direct entre les bulletins et les émargements nominatifs, les clefs de vérifications qui apparaissent dans la table suffrage et dans la table émargements ne sont pas les mêmes. Pour permettre de vérifier la cohérence de ces deux ensembles, des opérations de mélange et de chiffrement des clefs de vérification sont effectuées. Ainsi, pour chaque établissement, notre solution fournit les éléments suivants, où lec est le code de l'établissement :

- Un fichier `et_[lec]_shuffledCiphertexts`, contenant les clefs de vérification de la table suffrage correspondant à l'établissement considéré, après une opération de chiffrement et de mélange vérifiable. À chaque clef de vérification correspond donc un chiffré ElGamal, soit les points $(\tilde{a}, \tilde{b})$.
- Un fichier `et_[lec]_shuffleProof`, contenant la preuve de bon mélange des clefs de vérification (voir la section I.6.5.a).
- Un fichier `et_[lec]_expCiphertexts`, qui contient le résultat de l'exponentiation des éléments de `shuffledCiphertexts` (dans le même ordre) par la clef privée d'anonymisation $\mathsf{sk} = \mathsf{sk}_{\mathtt{anonymisation}}$. En d'autres termes, pour chaque chiffré $(\tilde{a}, \tilde{b})$, ce fichier contient un chiffré (u, v) tel que $u = \tilde{a}^{\mathsf{sk}}$ et $v = \tilde{b}^{\mathsf{sk}}$.
- Un fichier `et_[lec]_expProof.txt`, qui contient la preuve de bonne exponentiation (voir la section I.6.5.b).
- Un fichier `et_[lec]_partialDecryptions`, qui contient, pour chaque chiffré ElGamal (u, v) de `et_[lec]_expCiphertexts`, l'élément $w = v^{\mathsf{sk}_{\mathtt{mix}}}$, où $\mathsf{sk}_{\mathtt{mix}}$ est la clef de déchiffrement. (Avec les notations utilisées dans cette section, le déchiffré de (u, v) est alors u/w.) Ce fichier se présente sous le même format que `shuffledCiphertexts`, mais contient deux fois moins d'éléments.
- Un fichier `et_[lec]_partialProof.txt`, qui contient la preuve de validité du fichier`et_[lec]_parti` (voir la section I.6.5.b).

En plus de ces fichiers, nous fournissons également

- le fichier `clefPubliqueChiffrementMélange.txt`, qui contient la clef publique de chiffrement $\mathsf{pk}_{\mathtt{mix}}$ utilisée dans le mélange vérifiable ;
- le fichier `clefPubliqueAnonymisation.txt`, qui contient la clef publique d'anonymisation $\mathsf{pk}_{\mathtt{anonymisation}}$.

Tous ces fichiers sont regroupés dans une archive `dossierPreuvesLégitimité.zip`, qui est compressée au format zip. Pour effectuer ses contrôles, le tiers vérificateur pourra procéder établissement par établissement, et procéder aux vérifications suivantes :

1. Vérifier qu'il y a autant d'émargements que de bulletins.
2. Vérifier la preuve de bon mélange.
3. Vérifier que les deux clefs publiques contenues dans `clefPubliqueAnonymisation.txt` et `clefPubliqueChiffrementMélange.txt` sont bien des points de la courbe ; en particulier, qu'ils sont d'ordre q, où q est défini dans l'équation (1).

4. Vérifier la preuve d'exponentiation commune.
5. Vérifier la preuve de bon déchiffrement (qui est également une preuve d'exponentiation commune).
6. Pour tout $i \geq 1$, calculer $\mathsf{pk}_i = u_i/w_i$, où (u_i, v_i) est le $i$ème chiffré de `expCiphertexts` tandis que w_i est le $i$ème élément de `partialDecryptions`.
7. Vérifier qu'il n'y a pas de doublons sur les pk_i et que l'ensemble des pk_i est strictement égal à l'ensemble des clefs de vérification associées à l'établissement via la table suffrage, l'égalité sur les ensembles ne prenant pas compte de l'ordre des éléments.

IV.3 Dépouillement et preuves de déchiffrement

Un événement important qui survient après la clôture est la publication des résultats. Les résultats s'accompagnent de preuves cryptographiques qui garantissent leur cohérence avec l'urne dépouillée et se calculent en deux étapes : l'accumulation, qui a lieu juste après la clôture, et le dépouillement, qui a lieu quelques jours plus tard.

L'accumulation est un processus qui exploite la propriété d'homomorphisme du chiffrement ElGamal afin d'additionner entre eux les choix des électeurs, ce sans avoir à déchiffrer les bulletins. Plus précisément, la validité de chaque bulletin est revérifiée et les éléments de groupe des bulletins valides associés à une même sous-urne sont multipliés entre eux, ce qui donne une accumulation. Les bulletins invalides sont comptabilisés comme nuls.

Il faut effectuer une accumulation pour chaque résultat de comptage souhaité, ce qui signifie qu'il peut y en avoir plusieurs par élection. En l'occurrence, il y a une accumulation pour chaque liste électorale consulaire et une accumulation pour chaque élection. Les accumulations sont calculées par le SI VOTE et importées sur le SI RESULTAT. Afin de contrôler les accumulations, le tiers VIVU les recalcule à partir d'un export des urnes.

Le déchiffrement avec preuves répond au mécanisme de génération des fragments de clef, présenté en section II.3. Pour rappel, la clef de déchiffrement $\mathsf{sk}_{\mathsf{dec}}$ est séparée en plusieurs fragments qui sont conservés sous forme chiffrée dans des clefs USB stockées dans un coffre-fort. Chaque fragment est chiffré à l'aide d'une phrase secrète choisie par un membre du bureau de vote et connue de lui seul. De plus, un nombre minimum de fragments (noté t) est nécessaire afin d'effectuer une opération de déchiffrement, ce qui signifie qu'il faut qu'au moins t membres saisissent leur phrase secrète. Pour plus de sécurité, notre protocole ne reconstitue pas $\mathsf{sk}_{\mathsf{dec}}$ explicitement : à la place, t fragments de clef sont utilisés pour effectuer chacun un déchiffrement *partiel*. Ces derniers sont ensuite combinés afin d'effectuer le déchiffrement final, ce qui ne donne pas d'information sur $\mathsf{sk}_{\mathsf{dec}}$. Chacune de ces opérations de déchiffrement partiel s'accompagne d'une preuve de bon déchiffrement qui garantit que le fragment de clef a bien été utilisé.

Il faut effectuer un déchiffrement avec preuve par accumulation, ce qui donne autant de résultats de comptage. Toutes les opérations de déchiffrement s'effectuent sur le SI RESULTAT.

IV.3.1 Format des déchiffrements avec preuve

Les déchiffrements avec preuve sont regroupés dans un fichier au format csv qui contient les colonnes suivantes, séparées par des points-virgules (;) :

- ordrebureauvote, le numéro du bureau de vote, en commençant par 1 ;
- seuil, le nombre de fragments nécessaires pour recouvrer la clef ;
- ordreelection, le numéro de l'élection en commençant par 1 ;
- ordreetablissement, le numéro de l'établissement au sein de cette élection, à savoir LEC_NUM dans LCC (voir la section II.1) ;
- ordredechiffrement, le numéro du membre du bureau de vote (ou du fragment utilisé), en commençant par 1 ;
- serializedencodedpart, qui contient à la fois les déchiffrements partiels et les preuves associées.

Étant donné un membre du bureau de vote ayant pour numéro i et disposant d'un fragment de clef $\mathsf{sk_i}$, associé à une clef publique $\mathsf{pk_i} = g^{\mathsf{sk_i}}$ (où g est le générateur de la courbe elliptique), le déchiffré partiel du chiffré (A, B) est l'élément $F = A^{\mathsf{sk_i}}$. La preuve de bon déchiffrement associée est une preuve de connaissance de la préimage $\mathsf{sk_i}$ du couple $(\mathsf{pk_i}, F)$ par le morphisme $x \mapsto (g^x, A^x)$ (preuve de Chaum-Pedersen [CP92]).

IV.3.2 Vérification des preuves de bon déchiffrement

Dans cette section, nous considérons une ligne du fichier csv, qui contient un déchiffrement partiel effectué par un membre du bureau de vote (de numéro k) dont le fragment de clef (secret) est noté $\mathsf{sk_k}$ et dont la clef publique associée est notée $\mathsf{pk_k} = g^{\mathsf{sk_k}}$, où g est le générateur de la courbe (voir la section II.3). Pour simplifier, on suppose que cette ligne est rattachée à une LEC (et non à une circonscription électorale), mais un traitement similaire pourra être fait si ce n'est pas le cas (en considérant tous les bulletins rattachés à l'élection plutôt qu'à la LEC).

Tout d'abord, notons N le nombre de bulletins rattachés à l'établissement et $b_1, \cdots, b_N$, les bulletins en question. Notons n le nombre de choix pour l'élection rattachée à cet établissement (sans compter le vote blanc), de sort que chaque bulletin est de la forme $b_i = \{\alpha_{i,0}, \beta_{i,0}, \cdots, \alpha_{i,n}, \beta_{i,n}, \Pi\}$, où $i \in \{1, \cdots, N\}$, où $(\alpha_{i,j}, \beta_{i,j})$ représente un chiffré ElGamal (voir la section I.6.3) pour tout j et où Π représente l'ensemble de toutes les preuves à divulgation nulle de connaissance (PDN) attachées au bulletin. Rappelons qu'à chaque bulletin est associée une clef publique de vérification $\mathsf{pk_{anonyme}}$ ainsi qu'une signature ; ainsi, on peut définir I le sous-ensemble des $i \in \{1, \cdots, N\}$ pour lesquels b_i est valide, c'est-à-dire que les PDN associées et la signature sont valides. (Les bulletins b_i tels que $i \notin I$ doivent être comptabilisés comme des bulletins nuls.) En plus de vérifier que les bulletins sont valides, le vérifieur devra aussi s'assurer que leur empreinte appartient à l'ensemble des empreintes récupérées durant le scrutin.

Pour vérifier la preuve de déchiffrement partielle émise avec la clef $\mathsf{sk_k}$ pour l'accumulation de l'établissement considérée, le vérifieur commence par calculer l'accumulation des bulletins, c'est-à-dire le produit $A_j = \prod_{i \in I} \alpha_{i,j}$ pour tout $j \in \{0, \cdots, n\}$. Ensuite, le vérifieur

décode serializedencodedpart afin d'obtenir les déchiffrés partiels F_j et les preuves de validité associées. Il peut alors vérifier la validité des preuves.

Le vérifieur devra conserver la valeur de F_j ainsi que celle de $B_j = \prod_{i \in I} \beta_{i,j}$, qui seront utiles pour contrôler le résultat de comptage.

IV.3.3 Vérification du résultat de comptage

À chaque accumulation est associé un résultat $r_0, \cdots, r_n, r_\perp$, où chaque r_j est un nombre entier positif qui correspond au nombre d'électeurs ayant choisi l'option j (sauf $r_\perp$ qui correspond au nombre de votes nuls). La numérotation des options est prédéterminée et est cohérente dans le bulletin, dans les accumulations, dans les déchiffrements partiels et dans les résultats de comptage ; l'option 0 correspondant au vote blanc.

IV.3.3.a Format des résultats de comptage

Les résultats de comptage sont donnés dans deux fichiers séparés. Pour mieux les interpréter, on rappelle que la structure électorale est définie par les fichiers LCC et LCA (voir la section II.1), et on rappelle également que ces résultats ne concernent que le vote par internet (et pas les autres modalités de vote).

Le fichier RESULTAT_VPI est un fichier csv qui donne les résultats par liste électorale consulaire (LEC) et contient les colonnes suivantes.

- CODE_CIRC_ELEC, qui donne le code de la circonscription électorale (information redondante) ;
- CODE_LEC, qui donne le code de la LEC ;
- TYPE_LIGNE, qui vaut
  - C lorsque la ligne indique le nombre de voix reçues pour une candidature,
  - I lorsque la ligne indique le nombre d'électeurs inscrits dans cette LEC,
  - V lorsque la ligne indique le nombre de bulletins reçus pour cette LEC,
  - B lorsque la ligne indique le nombre de votes blancs dans cette LEC,
  - E lorsque la ligne indique le nombre de votes valablement exprimés dans cette LEC (information redondante),
  - N lorsque la ligne indique le nombre de bulletins nuls dans cette LEC ;
- CODE_CANDIDATURE indique le code de la candidature lorsque la ligne est de type "C" et est vide sinon ;
- NOMBRE donne le nombre indiqué dans cette ligne.

N.B. Dans le cas d'une élection de liste, le code candidature est le code candidature du candidat porteur de la liste.

Le fichier de résultat par circonscription est un fichier xlsx qui donne les résultats par circonscription électorale. Pour chaque circonscription électorale, il donne

- Le nom de la circonscription,
- Le nombre d'électeurs inscrits,
- Le nombre de bulletins reçus,

- Le nombre de votes blancs,
- Le nombre de votes nuls,
- Le nombre de suffrage valablement exprimés,
- Le taux de participation.

IV.3.3.b Vérification des résultats de comptage

Pour vérifier un résultat de comptage, le vérifieur doit le recalculer à l'aide de l'urne et des preuves de bon déchiffrement. Pour cela, il commence par vérifier les preuves de bon déchiffrement de tous les membres du bureau de vote (voir la section IV.3.2). Pour tout $j \in \{0, \cdots, n\}$ et pour chaque chaque membre, dont le numéro est un entier $k \geq 1$, on note B_j et $F_{j,k}$ les éléments de groupe mentionnés à la fin de la section IV.3.2. On note également $\mathcal{K}$ l'ensemble des t membres du bureau de vote pour lesquels on dispose d'un déchiffrement partiel (on rappelle que ces derniers sont regroupés dans un même fichier csv), où t est le nombre de fragments de clefs nécessaires pour le déchiffrement.

Pour tout $k \in \mathcal{K}$, on définit le coefficient de Lagrange

$$\lambda_k = \prod_{i \in \mathcal{K} \setminus \{k\}} \frac{i}{i-k},$$

où toutes les opérations sont effectuées dans le corps à q éléments, où q est défini dans l'équation (1). Ces coefficients permettent de calculer les valeurs de T_j pour tout $j \in \{0, \cdots, n\}$, selon l'identité

$$T_j = B_j \left(\prod_{k \in \mathcal{K}} F_{j,k}^{\lambda_k} \right)^{-1}.$$

Enfin, pour tout j, les résultats de comptage r_j peuvent être recalculés via l'égalité

$$r_j = \log_g(T_j),$$

où $\log_g$ représente le calcul du logarithme discret en base g, où g est le générateur du groupe. Comme r_j est majoré par le nombre de bulletins accumulés, ce logarithme n'est pas difficile à calculer.

En plus de la vérification que les résultats de comptage publiés soient les mêmes que ceux recalculés, nous conseillons au vérificateur d'effectuer les vérifications suivantes, pour chaque accumulation et pour chaque résultat associé :

- Vérifier, que $\sum_{j=0}^{n} r_j = N$, où N est le nombre de bulletins valides accumulés.
- Vérifier, pour tout j, $0 \leq r_j \leq N$, où N est le nombre de bulletins valides accumulés.

Conclusion

Un protocole de vote par internet est une construction complexe. Faisant intervenir de nombreux acteurs et visant des objectifs de sécurités exigeants, Voximius ne fait pas exception. Bien qu'il ne soit pas encore à la hauteur des exigences théoriques du monde académique, il intègre des problématiques de vérifiabilité et de transparence, ce sans perdre de vue les aspects pratiques et humains inhérents au vote. En particulier, nous avons intégré un mécanisme de détection du bourrage d'urne, et sans perturber l'expérience utilisateur, que ce soit lors de la réception des secrets d'authentification ou de leur renouvellement ; mieux : nous l'avons rendu compatible avec un mode d'authentification alternatif à la saisie d'un identifiant et d'un mot de passe. Au-delà de la légitimité des bulletins, nous avons partagé certaines responsabilités qui jusque-là étaient aux mains d'un même acteur, le MEAE en l'occurrence, notamment lors de la génération des secrets d'authentification et de la vérifiabilité individuelle : l'intégrité du scrutin s'en trouve renforcée.

Bibliographie

[Age21] Agence Nationale de la Sécurité des Systèmes d'Information (ANSSI). Guide de sélection d'algorithmes cryptographiques - v1.0, 2021. `https://cyber.gouv.fr/publications/mecanismes-cryptographiques`.

[BCC+22] Mikael Bougon, Hervé Chabanne, Véronique Cortier, Alexandre Debant, Emmanuelle Dottax, Jannik Dreier, Pierrick Gaudry, and Mathieu Turuani. Themis : An On-Site Voting System with Systematic Cast-as-intended Verification and Partial Accountability. In *ACM SIGSAC Conference on Computer and Communications Security, CCS 2022*. ACM, 2022.

[CDGH24] Véronique Cortier, Alexandre Debant, Anselme Goetschmann, and Lucca Hirschi. Election Eligibility with OpenID : Turning Authentication into Transferable Proof of Eligibility. In *33rd USENIX Security Symposium*. USENIX, 2024.

[CDS94] Ronald Cramer, Ivan Damgård, and Berry Schoenmakers. Proofs of Partial Knowledge and Simplified Design of Witness Hiding Protocols. In *CRYPTO '94*, volume 839, pages 174–187. Springer, 1994.

[CGG19] Véronique Cortier, Pierrick Gaudry, and Stéphane Glondu. Belenios : A Simple Private and Verifiable Electronic Voting System. In *Foundations of Security, Protocols, and Equational Reasoning*, volume 11565, pages 214–238. Springer, 2019.

[CGGI14] Véronique Cortier, David Galindo, Stéphane Glondu, and Malika Izabachène. Election Verifiability for Helios under Weaker Trust Assumptions. In *19th European Symposium on Research in Computer Security - ESORICS 2014*, Lecture Notes in Computer Science. Springer, 2014.

[CGGL24] Véronique Cortier, Pierrick Gaudry, Anselme Goetschmann, and Sophie Lemonnier. Belenios with Cast-as-Intended : Towards a Usable Interface. In *9th International Joint Conference on Electronic Voting, E-Vote-ID 2024*, Lecture Notes in Computer Science. Springer, 2024.

[Com19] Comission nationale de l'informatique et des libertés (CNIL). Sécurité des systèmes de vote par internet : la CNIL actualise sa recommandation de 2010, 2019. `https://www.cnil.fr/fr/securite-des-systemes-de-vote-par-internet-la-cnil-actualise-sa-recommandation-de-2010`.

[CP92] David Chaum and Torben P. Pedersen. Wallet Databases with Observers. In *Advances in Cryptology - CRYPTO 1992*. Springer, 1992.

[Eur02] European Telecommunications Standards Institute (ETSI). Policy requirements for certification authorities issuing qualified certificates, 2002.

https://www.etsi.org/deliver/etsi_ts/101400_101499/101456/01.02.01_60/ts_101456v010201p.pdf.

[Fed15] Federal Information Processing Standards Publication (FIPS). Secure Hash Standard (SHS), 2015. https://csrc.nist.gov/pubs/fips/180-4/upd1/final.

[Fed23] Federal Information Processing Standards Publication (FIPS). Digital Signature Standard (DSS), 2023. https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.186-5.pdf.

[HKLD17] Rolf Haenni, Reto E. Koenig, Philipp Locher, and Eric Dubuis. CHVote Protocol Specification. Cryptology ePrint Archive, Paper 2017/325, 2017. https://eprint.iacr.org/2017/325.

[JBS15] Michael B. Jones, John Bradley, and Nat Sakimura. JSON Web Token (JWT). *RFC*, 7519, 2015. https://doi.org/10.17487/RFC7519.

[JL17] Simon Josefsson and Ilari Liusvaara. Edwards-Curve Digital Signature Algorithm (EdDSA). *RFC*, 8032, 2017. https://doi.org/10.17487/RFC8032.

[Jos06] Simon Josefsson. The Base16, Base32, and Base64 Data Encodings. *RFC*, 4648, 2006. https://doi.org/10.17487/RFC4648.

[Jou14] Journal officiel de l'Union européenne. RÈGLEMENT (UE) No 910/2014 DU PARLEMENT EUROPÉEN ET DU CONSEIL du 23 juillet 2014 sur l'identification électronique et les services de confiance pour les transactions électroniques au sein du marché intérieur et abrogeant la directive 1999/93/CE, 2014. https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32014R0910.

[LHT16] Adam Langley, Mike Hamburg, and Sean Turner. Elliptic Curves for Security. *RFC*, 7748, 2016. https://doi.org/10.17487/RFC7748.

[MKR17] Kathleen M. Moriarty, Burt Kaliski, and Andreas Rusch. PKCS #5 : Password-Based Cryptography Specification Version 2.1. *RFC*, 8018, 2017. https://doi.org/10.17487/RFC8018.

[MZR+21] Karola Marky, Marie-Laure Zollinger, Peter B. Roenne, Peter Y. A. Ryan, Tim Grube, and Kai Kunze. Investigating Usability and User Experience of Individually Verifiable Internet Voting Schemes. *ACM Trans. Comput. Hum. Interact.*, 28(5), 2021.

[Nat23] National Institute of Standards and Technology (NIST). Recommendations for Discrete Logarithm-based Cryptography : Elliptic Curve Domain Parameters, 2023. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-186.pdf.

[ope23] openid.net. OpenID Connect Core 1.0 incorporating errata set 2, 2023. https://openid.net/specs/openid-connect-core-1_0.html.

[PS96] David Pointcheval and Jacques Stern. Security Proofs for Signature Schemes. In *Advances in cryptology - EUROCRYPT'96, International Conference on the Theory and Application of Cryptographic Techniques*. Springer, 1996.

[Sch89] Claus-Peter Schnorr. Efficient Identification and Signatures for Smart Cards. In *Advances in Cryptology - CRYPTO 1989*, volume 435. Springer, 1989.

[Sha79] Adi Shamir. How to Share a Secret. *Commun. ACM*, 22, 1979.

[Tah84] Taher El Gamal. A Public Key Cryptosystem and a Signature Scheme Based on Discrete Logarithms. In *CRYPTO'84*, 1984.

[TW10] Björn Terelius and Douglas Wikström. Proofs of Restricted Shuffles. In *Progress in Cryptology - AFRICACRYPT 2010*. Springer, 2010.

[Vox26] Voxaly. Code Source Public - Contexte Électeur, 2026. `https://github.com/Voxaly/meae-consulaires-2026`.

[Wik09] Douglas Wikström. A Commitment-Consistent Proof of a Shuffle. In *14th Australasian Conference on Information Security and Privacy - ACISP 2009*. Springer, 2009.